UNIVERSIDAD PRIVADA DE TACNA

FACULTAD DE INGENIERÍA

Escuela Profesional de Ingeniería de Sistemas

DISEÑO DE LA SOLUCIÓN TECNOLÓGICA

II UNIDAD

"Analyzing Traffic and Remote Desktop Connection Logs in Windows"

Que se presenta para el curso:

"SISTEMAS OPERATIVOS I"

Docente:

Dr. Renzo Alberto Taco Coayla

Integrantes:

Carrillo Quenta, Piere Fabricio (2024079966)

Avendaño Casapia, Dorian (2024080121)

Lupaca Calani, Mattias Alessandro (2024016553)

Franco Ramos, Dana (2024016556)

Del Pino, Fabiana (2024079971)

Rivera Chucuya, Leonel (2024079975)

Tacna – Perú

2026

CONTROL DEL DOCUMENTO

La Tabla 1 resume el control de versiones del documento.

Tabla 1

Control de versiones

Versión	Fecha	Responsable	Descripción del cambio
6.0	10/11/2026	Equipo del proyecto	Correcciones de la revisión por pares: cita faltante, APA, índice, consistencia de cifras y validación funcional del motor.
7.0	10/11/2026	Equipo del proyecto	Cierre de observaciones de la revisión por pares: referencias y APA, siglas, proxy TLS, vCPU, RNF-01a–c, STRIDE, anclas de riesgo, TCO y comparación con sistemas afines.
8.0	10/11/2026	Equipo del proyecto	Cierre de la revisión V7: cursivas y orden de las referencias, citas de autor corporativo, cita de la Tabla 18, riesgos S-11 y S-12, fuente horaria, custodia de copias, índice de anexos y ruta crítica.
9.0	10/11/2026	Equipo del proyecto	Incorporación de la corrida piloto y revisión de requisitos, pruebas, referencias y anexos.
10.0	10/11/2026	Equipo del proyecto	Alcance de la Unidad II y pruebas de aceptación de la Unidad III.
11.0	10/11/2026	Equipo del proyecto	Evidencia local del problema y plan de aceptación de la Unidad III.

Nota. Elaboración propia.

Aprobaciones

La Tabla 2 registra la aprobación del documento.

Tabla 2

Aprobación del documento

Rol	Nombre	Fecha
Director del proyecto / Representante del equipo	Mattias Lupaca	Pendiente

Nota. Elaboración propia.

ÍNDICE

RESUMEN EJECUTIVO 4
1. INTRODUCCIÓN Y VÍNCULO CON LA UNIDAD I 4
1.1. Síntesis de los hallazgos de la Unidad I 4
1.2. Brechas identificadas que el diseño resuelve 4
1.3. De la literatura al diseño 4
1.4. Protocolo de revisión y criterios de selección 5
2. PLANTEAMIENTO DEL PROBLEMA 5
2.1. Situación actual 5
2.2. Necesidad identificada 5
2.3. Justificación de la propuesta 5
3. OBJETIVOS, ALCANCE Y RESTRICCIONES 5
3.1. Objetivo general 5
3.2. Objetivos específicos 6
3.3. Alcance incluido 6
3.4. Fuera del alcance 6
3.5. Supuestos y restricciones 6
4. REQUERIMIENTOS 6
4.1. Usuarios y roles 6
4.2. Requerimientos funcionales 6
4.3. Requerimientos no funcionales 7
4.4. Matriz de trazabilidad 7
5. DISEÑO DE LA ARQUITECTURA 8
5.1. Visión general y decisiones de diseño 8
5.2. Arquitectura lógica 8
5.3. Arquitectura física 9
5.4. Componentes principales 9

5.5. Flujo de información 10
5.6. Secuencia de funcionamiento 10
5.7. Modelo de datos 11
6. DISEÑO DE LAS FUENTES DE DATOS Y LA CORRELACIÓN 12
6.1. Qué aporta cada fuente 12
6.2. Eventos de Windows a recolectar 12
6.3. Captura de tráfico RDP 13
6.4. Línea de tiempo de una sesión 13
6.5. Regla de correlación 13
7. DISEÑO DE INFRAESTRUCTURA 14
7.1. Servidores y equipos (hardware) 14
7.2. Sistemas operativos y software 15
7.3. Almacenamiento y virtualización 15
7.4. Servicios requeridos 15
8. DISEÑO DE RED 16
8.1. Topología 16
8.2. Segmentación y VLAN 16
8.3. Direccionamiento IP 17
8.4. Reglas de firewall 17
8.5. Acceso remoto y sincronización horaria 17
9. DISEÑO DE SEGURIDAD 18
9.1. Riesgos y amenazas 18
9.2. Controles propuestos 19
9.3. Gestión de accesos 19
9.4. Respaldo y recuperación 19
9.5. Monitoreo y auditoría 19
9.6. Privacidad y ética 20
10. DISEÑO DEL MOTOR DE DETECCIÓN Y PUNTUACIÓN DE RIESGO 20
10.1. Indicadores y reglas 20
10.2. Puntuación 0–100 y umbrales 21
10.3. Clasificación de conexiones 21
10.4. Alerta explicable 21
10.5. Aprendizaje automático (trabajo futuro) 22
11. DISEÑO DE LA INTERFAZ Y PROTOTIPO 22
11.1. Mapa de navegación 22
11.2. Pantallas del prototipo 22
11.3. Enlace al prototipo y criterios de usabilidad 23
12. DISEÑO OPERATIVO 23
12.1. Roles y responsabilidades (RACI) 23
12.2. Procedimientos de operación 24
12.3. Procedimientos de mantenimiento 24
12.4. Gestión de incidentes 24
13. PLAN DE IMPLEMENTACIÓN (UNIDAD III) 24
13.1. Actividades, recursos y dependencias 24
13.2. Cronograma 25
14. PLAN DE PRUEBAS 25
14.1. Estrategia 25
14.2. Casos de prueba 26
14.3. Métricas de evaluación 26
14.4. Evidencia del diseño y validación prevista 27
15. ANÁLISIS DE FACTIBILIDAD 27
15.1. Factibilidad técnica 27
15.2. Factibilidad económica 27
15.3. Factibilidad operativa 28
16. CONCLUSIONES Y RECOMENDACIONES 28
16.1. Conclusiones 28
16.2. Recomendaciones 29
REFERENCIAS BIBLIOGRÁFICAS 29
ANEXOS 36
ANEXO A. DIAGRAMAS A TAMAÑO COMPLETO 36
ANEXO B. TABLA COMPLETA DE EVENTOS DE WINDOWS 36
ANEXO C. DICCIONARIO DE DATOS 37
ANEXO D. REGLAS DE DETECCIÓN DETALLADAS 38
ANEXO E. MATRIZ DE TRAZABILIDAD 38
ANEXO F. PROTOTIPO EN FIGMA (CAPTURAS Y ENLACE) 38
ANEXO G. REGISTRO DE CONTROL DE FUENTES ACTUALIZADO 38
ANEXO H. GLOSARIO 39
ANEXO I. ENLACE AL REPOSITORIO 39
ANEXO P. COMPARACIÓN CON SISTEMAS AFINES 39
ANEXO Q. EVIDENCIA DOCUMENTAL DEL LABORATORIO 40
Q.1. Antecedente de adquisición y correlación 40

RESUMEN EJECUTIVO

Los metadatos del tráfico de Escritorio remoto (RDP) identifican el origen, el destino y la hora de una conexión. Los eventos de Windows aportan información sobre el resultado de la autenticación y el estado de la sesión. La investigación manual requiere cotejar ambas fuentes para reconstruir el caso y determinar qué asociaciones respalda la evidencia.

El proyecto propone un laboratorio aislado de cuatro máquinas virtuales (VM). Un colector en Windows reúne los registros y los envía por HTTPS (protocolo seguro de transferencia de hipertexto) a un servidor de análisis. El servidor organiza la evidencia, relaciona los registros y deja pendientes las asociaciones ambiguas. El prototipo de Figma muestra tres escenarios simulados que representan un acceso normal, una alerta y una asociación ambigua.

La Unidad II entrega la arquitectura, el prototipo y el plan de pruebas. El motor de reglas se comprobó con siete casos sintéticos. En uno de ellos, la alerta AL-018 obtuvo 90/100. La detección de al menos el 90 % de los casos positivos de prueba es una meta de aceptación para la Unidad III. El costo incremental referencial asciende a S/ 2 222,80 (Anexo L).

1. INTRODUCCIÓN Y VÍNCULO CON LA UNIDAD I

1.1. Síntesis de los hallazgos de la Unidad I

La revisión de la Unidad I abarcó seis frentes: fundamentos de RDP, tráfico, registros, amenazas, monitoreo y detección forense. Los estudios de tráfico demuestran que el volumen y la temporización caracterizan conexiones cifradas, aunque su utilidad depende del escenario de observación (Lapczyk y Skillicorn, 2020; Magaña et al., 2019); el análisis del sistema operativo aporta lo que la red no ofrece: la autenticación y el estado de la sesión (Microsoft, 2021a).

T. Bai et al. (2019) muestran el valor de las sesiones RDP para estudiar el movimiento lateral. Adoptamos reglas deterministas con evidencia de procedencia, que permiten reproducir casos pequeños, y descartamos un detector entrenado que exigiría datos adicionales (Hassan et al., 2019; Smiliotopoulos et al., 2023).

1.2. Brechas identificadas que el diseño resuelve

El análisis de la Unidad I dejó tres brechas. La primera aparece cuando red y sistema operativo se investigan por separado y el analista pierde el contexto que une ambos registros. La segunda surge al coincidir varios intentos sobre una misma IP: un emparejamiento temporal devuelve una asociación ambigua que la evidencia disponible no permite resolver. La tercera afecta la reproducibilidad, porque un puntaje sin eventos de respaldo, ventana ni versión de regla no puede auditarse. El diseño ataca las tres: conserva los identificadores de evidencia, califica cada asociación y permite recorrer la cronología del caso.

1.3. De la literatura al diseño

La Tabla 3 ordena las fuentes en seis subtemas y las conecta con una decisión concreta de diseño. El Anexo P (Tabla 28) compara el diseño con los cuatro sistemas más cercanos —NoDoze, Wazuh con Suricata, el NDR de Amoretti y el SIEM de Vaarandi y Mäses—: ninguno cruza el registro del host con el flujo RDP, conserva la asociación ambigua ni versiona el puntaje, que son las tres brechas del §1.2. Las métricas de esos trabajos no se trasladan al laboratorio y el Anexo E enlaza requisitos y pruebas y el Anexo G registra el cotejo bibliográfico.

Tabla 3

Hallazgos y decisiones de diseño

Subtema	Fuentes clave	Hallazgo	Decisión de diseño
Bases RDP	Microsoft (2018a); Souppaya y Scarfone (2016)	El acceso remoto combina protocolo y controles de entrada.	Host RDP autorizado, autenticación a nivel de red (NLA), TLS y segmentación.
Tráfico	Magaña et al. (2019); Lapczyk y Skillicorn (2020)	El flujo aporta características observables aun con cifrado.	Conservar metadatos y dirección del flujo.

Subtema	Fuentes clave	Hallazgo	Decisión de diseño
Registros	Microsoft (2021a); Hassan et al. (2019)	El contexto de eventos reduce investigaciones aisladas.	Correlación con evidencia trazable y estado de calidad.
Amenazas	T. Bai et al. (2019); Rose et al. (2020)	El acceso remoto puede formar parte de secuencias de movimiento lateral.	Controles de acceso y reglas por origen y cuenta.
Monitoreo	Smiliotopoulos et al. (2023); Wireshark Foundation (s. f.)	La telemetría del host complementa la visibilidad de red.	Captura acotada y tablero con detalle de alertas.
Detección y forense	Hassan et al. (2019); Smiliotopoulos et al. (2023)	El contexto y las pruebas reproducibles facilitan la revisión.	Versionar reglas y evaluar con casos etiquetados.

Nota. Elaboración propia.

1.4. Protocolo de revisión y criterios de selección

El equipo utilizó IA generativa para proponer candidatos bibliográficos y buscó sus títulos y autores en Google Académico, IEEE y las referencias de los trabajos recuperados. Seleccionó fuentes identificables y contrastó sus datos con registros y copias. El corpus conserva 83 PDF. La bibliografía contiene 88 entradas, de las cuales 50 tienen DOI. La selección fue dirigida y careció de ecuaciones, cribado por pares y conteos por etapa. El Anexo G documenta el alcance de la comprobación de cada entrada.

2. PLANTEAMIENTO DEL PROBLEMA

2.1. Situación actual

El aviso conjunto sobre Akira reportó más de 250 organizaciones afectadas al 1 de enero de 2024. Identificó los servicios expuestos, incluido RDP, entre varias vías de acceso inicial (Federal Bureau of Investigation et al., 2024). El total corresponde a la campaña y no atribuye los casos a RDP ni representa una medición de la UPT.

El 10 de noviembre de 2026, una captura de diagnóstico del laboratorio registró 412 paquetes y cinco inicios de flujo TCP entre el cliente y el servidor en 267,672 s. El evento de desconexión 4779, registro 1198, identifica la IP del cliente y omite el puerto de origen. El único evento 4624 exportado es de tipo 5, correspondiente a un servicio, y ocurrió fuera del intervalo de la captura. El flujo TCP 4 comenzó 8,603 s antes de la desconexión. La proximidad temporal lo hace un candidato y los campos disponibles dejan el vínculo sin confirmar (Anexo Q, Tabla Q1).

2.2. Necesidad identificada

Este contraste documenta el problema de diseño. La captura describe el intercambio entre equipos y el registro de Windows aporta información sobre el resultado y el estado de la sesión. El tablero debe reunir origen, cuenta, resultado y evidencia, y distinguir vínculos confirmados, pendientes y sin asociación. Cuando haya varios candidatos compatibles, se conservarán junto con el motivo de la incertidumbre.

2.3. Justificación de la propuesta

La Unidad II entrega el diseño y el prototipo de interfaz. El antecedente documental sustenta la captura, la conservación de procedencia y la asociación de registros previstas en RF-01 a RF-03. Figma permite revisar la navegación, las alertas y el tratamiento de asociaciones ambiguas. El plan de la Unidad III comprobará adquisición, correlación y aceptación del tablero.

3. OBJETIVOS, ALCANCE Y RESTRICCIONES

3.1. Objetivo general

Al cierre de la Unidad II, entregar el diseño trazable del monitor RDP, con cuatro diagramas técnicos, tres escenarios simulados navegables y nueve casos de aceptación documentados.

3.2. Objetivos específicos

OE-01. Al cierre de la Unidad II, especificar eventos y flujos con host, origen, hora y procedencia. CP-01 y CP-05 definen cómo comprobar preservación e idempotencia.

OE-02. Al cierre de la Unidad II, documentar el vínculo en la ventana [t−15 s, t+5 s], con estados confirmado, pendiente y sin asociación. CD-03 exige conservar ambos candidatos.

OE-03. Al cierre de la Unidad II, representar tres casos en Figma y documentar los resultados esperados: AL-018 con 90/100, acceso normal con 0/100 y asociación ambigua pendiente.

OE-04. Al cierre de la Unidad II, entregar cuatro diagramas, seis reglas de filtrado y una matriz que vincule doce riesgos con criterios de aceptación para una eventual implementación.

3.3. Alcance incluido

El alcance comprende un cliente autorizado, un host RDP Windows, un servidor de análisis y un firewall virtual. El diseño cubre el inicio, los fallos, el éxito, la reconexión, la desconexión, el cierre y la creación de procesos seleccionados; las reglas, la revisión manual y la exportación CSV pertenecen al prototipo. Para representar la apertura de Word usamos la creación de WINWORD.EXE cuando la instalación autorizada lo incluye, y un ejecutable de prueba permitido cuando el laboratorio carece de Word.

3.4. Fuera del alcance

Quedan fuera RustDesk, la exposición pública de RDP, el descifrado de contenido, la captura de teclado o pantalla, el seguimiento de ventana activa, la respuesta automática de contención y el aprendizaje automático operativo. Una creación de proceso 4688 registra el arranque del ejecutable, incluso si fue en segundo plano. El diseño mantiene separadas la ejecución, el primer plano y la duración de uso.

3.5. Supuestos y restricciones

Se utilizarán máquinas propias o asignadas, cuentas ficticias y un único host RDP inicial. Las 16 semanas corresponden a la planificación académica de la plantilla. El desarrollo previsto ocupa las semanas 9 a 15. La disponibilidad de Windows Server, Windows cliente y herramientas de captura depende de licencias o evaluaciones autorizadas. Los umbrales y capacidades descritos son metas de diseño para verificar posteriormente.

4. REQUERIMIENTOS

4.1. Usuarios y roles

La Tabla 4 describe los roles y las necesidades de cada uno.

Tabla 4

Roles de usuario y responsabilidades

Rol	Descripción	Necesidades principales
Administrador de TI	Opera hipervisor, red y colector.	Diagnóstico de fuentes, reloj y conectividad.
Analista de seguridad	Investiga conexiones y revisa alertas.	Filtros, motivos, cronología y exportación.
Responsable del sistema	Administra reglas y acepta cambios.	Versiones, autorizaciones y registro de operaciones.

Nota. Elaboración propia.

4.2. Requerimientos funcionales

Los requerimientos funcionales se enumeran en la Tabla 5.

Tabla 5

Requerimientos funcionales

ID	Requerimiento	Prioridad	Objetivo asociado
RF-01	Ingerir eventos de arranque, apagado, autenticación y sesiones RDP.	Alta	OE-01

ID	Requerimiento	Prioridad	Objetivo asociado
RF-02	Extraer metadatos TCP/UDP del host y conservar procedencia y reloj.	Alta	OE-01
RF-03	Asociar eventos, flujos y sesiones con resultado y nivel de confianza.	Alta	OE-02
RF-04	Puntuar patrones, publicar alertas y exponer evidencia por regla.	Alta	OE-03
RF-05	Mostrar conexiones, métricas, sesiones y estado de fuentes.	Alta	OE-03
RF-06	Asociar WINWORD.EXE, notepad.exe o calc.exe cuando exista una clave fiable de sesión. Aplicar la lista versionada al nombre base del ejecutable.	Media	OE-02
RF-07	Exportar CSV y registrar accesos, exportaciones y cambios de reglas.	Media	OE-03 y OE-04

Nota. Elaboración propia.

El administrador propone cambios a la lista de RF-06, el responsable los aprueba y la bitácora conserva la versión. Antes de publicar la lista se repite CP-03 para comprobar el vínculo y el descarte de procesos ajenos a la lista.

4.3. Requerimientos no funcionales

La Tabla 6 fija la métrica de cada atributo no funcional.

Tabla 6

Requerimientos no funcionales y métricas

ID	Atributo	Requerimiento	Métrica
RNF-01a	Disponibilidad	Mantener el servicio HTTPS durante la corrida normal.	≥ 99 % de sondeos HTTPS válidos (119/120 en CP-09).
RNF-01b	Recuperación de ingesta	Recuperar la ingesta tras un corte de 10 min a 50 eventos/s.	En ≤ 30 min desde el inicio del corte, persistir 30 000 eventos únicos sin duplicados (CP-05).
RNF-01c	Recuperación de datos	Restaurar PostgreSQL desde la copia y verificar datos y reglas.	RPO ≤ 24 h y RTO ≤ 2 h (CP-07).
RNF-02	Seguridad	Todo acceso al tablero exige autenticación multifactor (MFA) y toda operación queda auditada; el control por rol se aplica en la API.	100 % de accesos con MFA válido y registro de auditoría por operación; cero accesos fuera de rol en los 12 intentos de CP-06.
RNF-03	Rendimiento	Mantener latencia de telemetría y consulta acotadas.	p95 ≤ 20 s al tablero y ≤ 2 s por consulta típica.
RNF-04	Escalabilidad	Admitir carga de prueba sostenida.	50 eventos/s durante 10 min sin pérdida.
RNF-05	Mantenibilidad	Versionar reglas y configuración y permitir revertir un cambio sin perder la evidencia asociada.	Restaurar la versión anterior de una regla en ≤ 10 min y reproducir su puntaje previo (CP-07).
RNF-06	Usabilidad	Permitir encontrar una alerta y su evidencia.	Al menos 4 de 5 personas completan la tarea en ≤ 2 min.

Nota. Elaboración propia.

4.4. Matriz de trazabilidad

La Tabla 7 encadena objetivos, requisitos, componentes y pruebas.

Tabla 7

Trazabilidad de objetivos a pruebas

Objetivo	Requisito	Componente	Prueba
OE-01	RF-01, RF-02, RNF-01b	Colector, sensor, API	CP-01, CP-05
OE-02	RF-03, RF-06	Correlador, base de datos	CP-02, CP-03
OE-03	RF-04, RF-05, RF-07	Motor, tablero, API	CP-04, CP-06

Objetivo	Requisito	Componente	Prueba
OE-04	RNF-01a, RNF-01c y RNF-02 a RNF-06	Plataforma y procedimientos	CP-06 a CP-09

Nota. Elaboración propia.

La matriz del anexo E detalla la verificación individual y el dato que se conservará como evidencia.

5. DISEÑO DE LA ARQUITECTURA

5.1. Visión general y decisiones de diseño

La Tabla 8 recoge las alternativas evaluadas y el motivo de la elección.

Tabla 8

Alternativas de diseño

Decisión	Alternativa considerada	Motivo
Get-WinEvent y XML	Lectura manual o interpretación de mensajes traducidos	Los campos XML conservan nombres y tipos sin depender del idioma.
TShark/Npcap en el host	Captura en otro segmento	Se observa el punto de llegada de RDP y se acota el filtro.
FastAPI y PostgreSQL	Plataforma SIEM (gestión de eventos e información de seguridad) empresarial	Esquema relacional y reglas manejables en un laboratorio.
Reglas versionadas	Modelo supervisado inicial	Resultados reproducibles con pocos ejemplos etiquetados.
Tablero web con sondeo de 5 s	Flujo permanente de mensajes en el navegador	Simplifica recuperación, autenticación y prueba de latencia.

Nota. Elaboración propia.

Registro de decisiones de arquitectura (ADR). Cada alternativa de la Tabla 8 queda documentada además con la consecuencia que se acepta y el criterio que obligaría a revisarla, de modo que un cambio futuro se decida contra un criterio explícito.

ADR-01 · Base de datos relacional. PostgreSQL 16 sustituye a la plataforma SIEM y a SQLite como almacén de evidencias. Consecuencia aceptada: administrar respaldos, WAL y vaciados periódicos, y asumir que un solo servidor no ofrece alta disponibilidad. Criterio de reversión: si la carga sostenida supera los 200 eventos por segundo o la base excede los 80 GB, migraremos a una instancia dedicada o a TimescaleDB.

ADR-02 · Reglas deterministas antes que un modelo supervisado. Las reglas versionadas sustituyen al clasificador entrenado. Consecuencia aceptada: menor capacidad ante patrones nuevos y dependencia del ajuste manual de umbrales. Criterio de reversión: cuando existan al menos 300 escenarios etiquetados con separación temporal entre ajuste y prueba, evaluaremos un modelo supervisado como segunda opinión.

ADR-03 · Sondeo de cinco segundos en lugar de flujo permanente. El tablero consulta la API cada cinco segundos en vez de mantener una conexión abierta. Consecuencia aceptada: hasta cinco segundos de latencia entre la evidencia y su visualización, y carga repetida sobre la API. Criterio de reversión: si CP-09 no alcanza el p95 de 20 s o el sondeo eleva la CPU por encima del 60 %, evaluaremos WebSocket o Server-Sent Events.

5.2. Arquitectura lógica

El diseño responde a un pipeline por capas —adquisición, transporte, normalización, correlación y presentación— con una cola persistente como amortiguador entre la adquisición y el procesamiento. El servicio de ingesta valida el certificado y normaliza los lotes antes de registrarlos en PostgreSQL; un trabajador correlaciona y evalúa reglas; FW-RDP controla el tránsito entre las cuatro zonas y el tablero consulta la API con permisos por rol (Figura 1). Descartamos un bus de eventos dedicado, como Kafka o RabbitMQ, porque añadiría un servicio que el equipo no puede operar con garantías en cuatro VM: la cola en PostgreSQL cubre el mismo requisito de durabilidad con menos componentes. A 50 eventos/s y 1 KiB por evento, un corte de 10 min acumula 30 000 eventos (29,3 MiB de datos).

CP-05 verifica esa capacidad en la cola local del colector, que retiene el lote hasta recibir confirmación. La cuota de 2 GB corresponde a la cola central en ANL-RDP.

Figura 1

Arquitectura general: vista lógica y flujo de la evidencia



Nota. Elaboración propia.

Se mantienen entidades distintas para flujo, sesión y autenticación. El transporte describe la conexión y sus canales, y el SessionId lo asigna el host (Microsoft, 2018a, 2018b). CredSSP interviene antes del inicio interactivo, por lo que un flujo o una autenticación previa por sí solos no confirman una sesión (Microsoft, 2024a, 2026b).

El laboratorio fija un único host Windows y RDP. Se excluye un escritorio como servicio porque añadiría un entorno de ejecución diferente (Atanassov et al., 2024). Las comparaciones entre protocolos dependen del escenario de virtualización, que aquí debe mantenerse fijo (Magaña et al., 2019; Şeşen y Kara, 2018).

Mantenemos constantes la carga y el enlace durante toda la comparación. El comportamiento de los clientes ligeros depende tanto de la red como de la aplicación (Lai y Nieh, 2006; S. J. Yang et al., 2002), y la propia arquitectura modifica el desempeño, de modo que extrapolar tasas medidas en otra plataforma carecería de validez (Schlosser et al., 2007).

5.3. Arquitectura física

CLI-RDP y WIN-RDP ocupan redes virtuales separadas y solo se alcanzan a través del firewall. El host Windows ejecuta el colector y el sensor; el servidor ANL-RDP concentra la API, el trabajador, el tablero y la base de datos, y PostgreSQL escucha únicamente en la interfaz local. Un medio de respaldo, independiente del disco virtual de análisis, conserva las copias cifradas.

5.4. Componentes principales

La Tabla 9 detalla los componentes, su entrada y su salida.

Tabla 9

Componentes de la solución

Componente	Función	Entrada	Salida	Tecnología
Colector Windows	Leer canales y preparar lotes	XML de Windows	Eventos normalizados mínimamente	PowerShell / Get-WinEvent
Sensor RDP	Observar y resumir flujos	TCP/UDP 3389	Metadatos direccionales	Npcap / TShark
API de ingesta	Autenticar y deduplicar	Lote JSON	Confirmación por evento	FastAPI / HTTPS
Correlador y reglas	Asociar y puntuar	Eventos y flujos	Sesiones, alertas y evidencias	Python / PostgreSQL

Componente	Función	Entrada	Salida	Tecnología
Tablero	Consultar y exportar	API de lectura	Vistas y CSV	HTML, CSS y JavaScript
Proxy TLS inverso	Termina mTLS y separa ingesta de tablero	Certificado de cliente y sesión	Tráfico HTTPS validado	nginx sobre ANL-RDP

Nota. Elaboración propia.

Elegimos un colector Windows, una base relacional y un tablero propio porque el equipo puede auditar cada vínculo sin sostener un SIEM completo. Los SIEM de infraestructura crítica y de nube documentan integraciones de mayor alcance (González-Granadillo et al., 2021; Tuyishime et al., 2023); Wazuh con Suricata añade detección y aviso, y el NDR de Amoretti se concentra en la red (Amoretti, 2025; Lisnevskyi et al., 2026). Ninguna de esas plataformas cabe en un centro de monitoreo con recursos limitados, que es el escenario que aquí priorizamos (Vaarandi y Mäses, 2022).

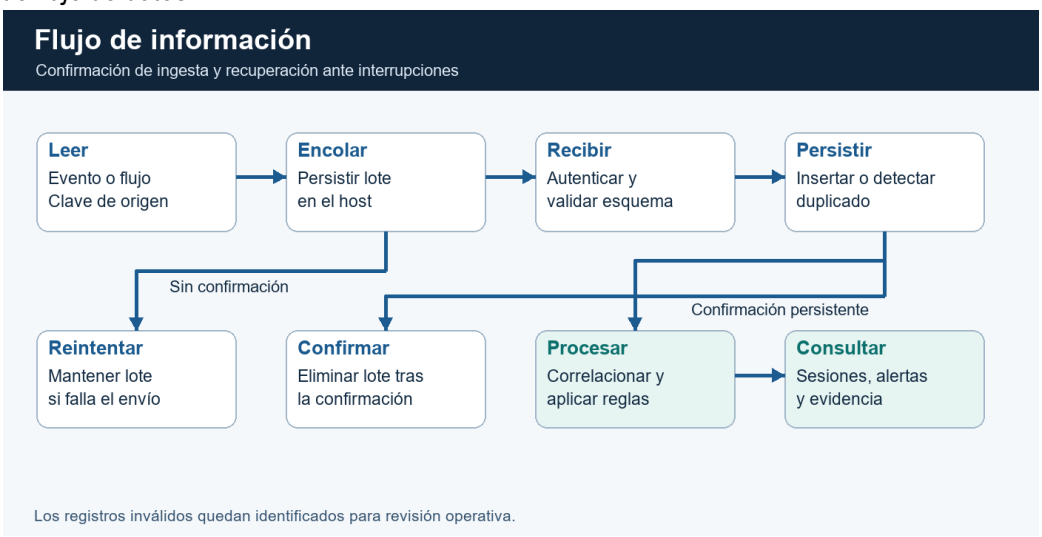
Partimos del canal Security como fuente inicial y dejamos Sysmon como alternativa para ampliar eventos cuando existan configuración y muestras verificables (Smiliotopoulos et al., 2022; Smiliotopoulos et al., 2023). El responsable retiene la decisión de contención: la automatización que estudian Tanimu et al. (2026) queda fuera porque nuestra señal de riesgo exige revisión humana.

5.5. Flujo de información

El colector identifica cada registro por host, canal, época del canal y EventRecordID. Conserva el lote en una cola local hasta que el servidor confirma la inserción persistente o reconoce el duplicado; la API rechaza cualquier esquema inválido y registra el motivo. Un trabajador consume los trabajos pendientes con transacciones, reintentos acotados e identificadores idempotentes, y los atrasos permanecen visibles en el tablero (Figura 2).

Figura 2

Diagrama de flujo de datos



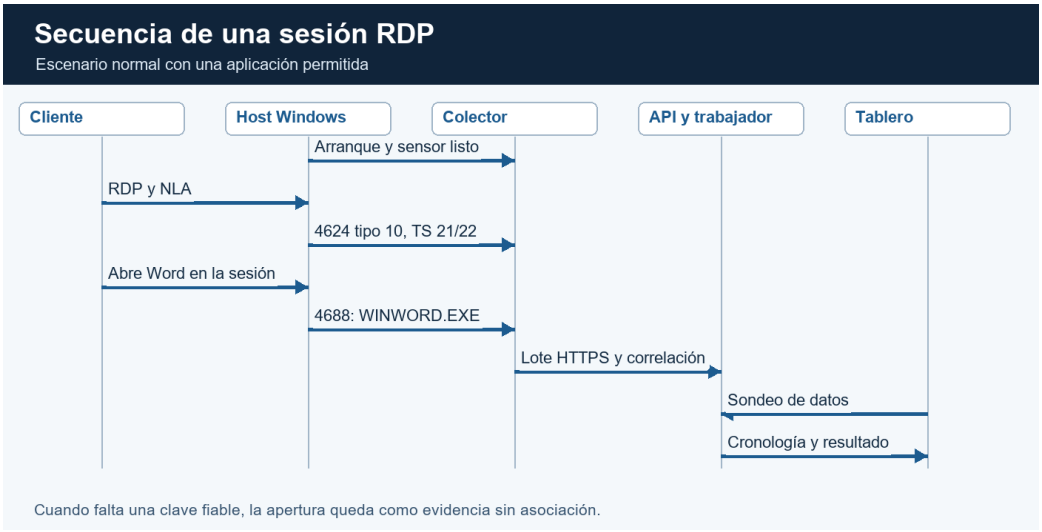
Nota. Elaboración propia.

5.6. Secuencia de funcionamiento

Cuando Windows arranca, el servicio de auditoría habilitado produce la evidencia de arranque y una tarea programada inicia la captura. El cliente autorizado solicita RDP; el sensor observa el flujo y Windows registra el resultado de la autenticación. Un 4624 de tipo 10 confirma el inicio remoto interactivo y Terminal Services añade el estado de la sesión. Si el usuario abre Word, el 4688 se vincula solo cuando coinciden host, época de arranque e identificador de inicio de sesión. El tablero muestra la secuencia y las reglas activadas en el siguiente sondeo (Figura 3).

Figura 3

Diagrama de secuencia del registro de una sesión remota



Nota. Elaboración propia.

5.7. Modelo de datos

La Tabla 10 define los campos del evento normalizado.

Tabla 10

Campos principales del evento normalizado

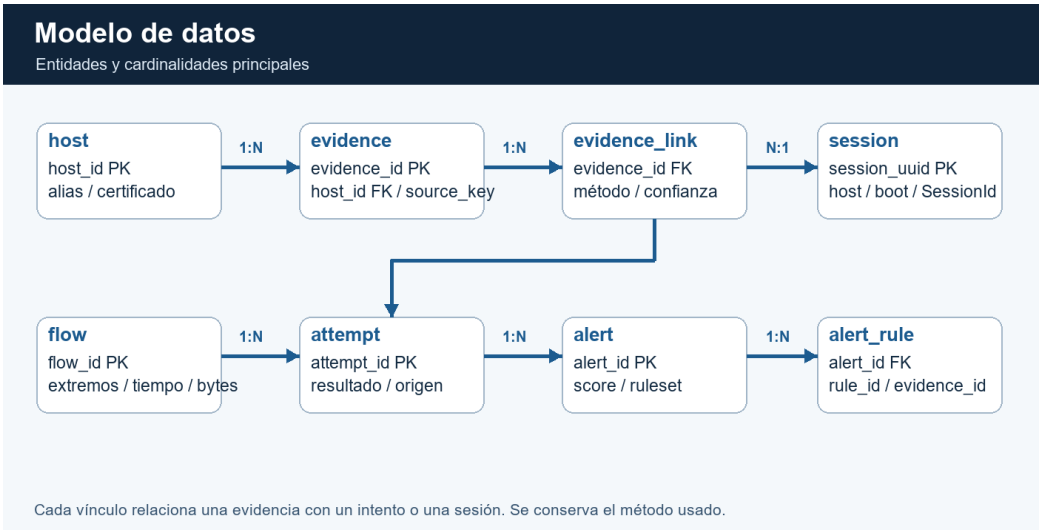
Campo	Tipo	Origen	Descripción
evidence_id	UUID	Ingesta	Referencia estable de la evidencia.
host_id	UUID	Configuración	Host observado, registrado por el colector.
event_time / received_at	timestamptz	Log / API	Ocurrencia UTC y recepción UTC.
source_key	text	Log o sensor	Clave idempotente, única por fuente.
source_ip / source_port	inet / integer	Red o log	Valores opcionales, con origen explícito.
logon_key / session_id	text / integer	Windows	Claves locales y diferenciadas.
kind / payload	text / jsonb	Normalizador	Tipo y campos permitidos del evento.

Nota. Elaboración propia.

Se separan evidencia, intento y sesión. La tabla de vínculos guarda método, confianza, diferencia temporal y versión de correlación. Una alerta conserva su versión de reglas y las evidencias que justifican el cálculo. Índices por host y tiempo, IP y tiempo, y claves de sesión apoyan la consulta. Las claves foráneas y transacciones evitan publicar alertas huérfanas. Véase la Figura 4.

Figura 4

Modelo entidad-relación



Nota. Elaboración propia.

6. DISEÑO DE LAS FUENTES DE DATOS Y LA CORRELACIÓN

6.1. Qué aporta cada fuente

La Tabla 11 compara lo que aporta y lo que no aporta cada fuente.

Tabla 11

Información observable por fuente

Fuente	Qué aporta	Qué no aporta	Método
Tráfico TCP/UDP	Extremos, puertos, bytes, tiempos y dirección	Cuenta y resultado de autenticación	Npcap / TShark
Security	Cuenta, resultado, tipo, IP cuando figura, LogonId	Volumen y duración del flujo	Get-WinEvent
Terminal Services	Autenticación de red, inicio, reconexión y desconexión	Confirmación universal de acceso interactivo	Canales operacionales
System	Evidencia de arranque y estado del sistema	Identidad del usuario remoto	Get-WinEvent

Nota. Elaboración propia.

6.2. Eventos de Windows a recolectar

La Tabla 12 enumera los eventos que se recolectarán.

Tabla 12

Eventos de Windows del prototipo

Evento	Registro	Significado	Uso
4624, 4625	Security	Inicio exitoso, intento fallido	4624 tipo 10 como evidencia fuerte. 4625 tipo 3 solo con respaldo contextual.
4634, 4647	Security	Cierre completado, solicitud de cierre	Distinguir el final del inicio de cierre.
1149	RemoteConnectionManager/Operational	Autenticación de red en el canal de RDP	Señal de apoyo para asociar una conexión.
21, 22, 23, 24, 25	LocalSessionManager/Operational	Inicio, shell, cierre, desconexión, reconexión	Estados de sesión, asociados por host y sesión.
4688, 4672	Security	Nuevo proceso, privilegios especiales	Actividad permitida y contexto de riesgo.

Evento	Registro	Significado	Uso
6005, 6006, 6008	System / EventLog	Servicio de eventos iniciado, detenido o apagado inesperado detectado	Delimitar arranque y cierre con evidencia adicional.
4778, 4779	Security	Reconexión y desconexión de sesión	Corroborar LSM 25/24 por host y Logon ID. No puntúan por sí solos.

Nota. Elaboración propia.

Habilitaremos la auditoría de inicio de sesión y de creación de procesos y registraremos los campos en XML, sin guardar la línea de comandos. La prueba de compatibilidad fijará los eventos y campos que ofrece la compilación elegida. La hora del evento 6008 se interpreta con los campos del proveedor y no la tomamos como hora de pérdida de energía.

6.3. Captura de tráfico RDP

El filtro cubre el host autorizado y los puertos TCP o UDP 3389 (Microsoft, 2026a). TShark extrae marca de tiempo, IP, puerto, protocolo, longitud y banderas TCP (Wireshark Foundation, s. f.), y agregamos por dirección y flujo. La clave de transporte combina extremos, puertos, protocolo y época de conexión; un SYN retransmitido conserva la misma época si coincide con el intento de transporte. Reportamos el flujo en incrementos de cinco segundos y reservamos un búfer temporal de cuatro archivos de 25 MB para el diagnóstico en escenarios autorizados. La persistencia central recibe únicamente metadatos.

Repetimos el mismo perfil de carga en cada escenario, porque el tráfico de escritorios virtuales y la experiencia de uso varían con el enlace (Kist y Maxwell, 2012; Pessolani, 2011). Las características del host también alteran las señales temporales, y por eso descartamos identificar al usuario por su patrón de tecleo (Kuzminykh et al., 2020).

RF-02 conserva metadatos, en vez de clasificar actividades cifradas, porque los modelos publicados requieren datos y validación adicionales (Lapczyk y Skillicorn, 2020; J. Yang et al., 2026). La medición de interactividad requiere otra instrumentación (Arellano-Uson et al., 2021). El evento 4688 documenta creación de proceso y no su tiempo de uso.

TShark captura los metadatos de TCP y UDP 3389 (Zeas Martínez, 2011), mientras que la atribución del origen se contrasta con la evidencia del host y con la hora del flujo (Archila Morán, 2024).

6.4. Línea de tiempo de una sesión

El host arranca, el sensor observa la conexión y los eventos registran el intento con su resultado. El estado de sesión pasa a activo cuando aparece la evidencia de inicio; una desconexión cierra el intervalo activo pero conserva la sesión para una reconexión posterior, y un cierre confirmado la termina. Si el host se apaga sin cierre, el sistema deja la duración como estimada y conserva la causa del final incompleto.

6.5. Regla de correlación

Normalizamos IP, host y UTC. Un 4624 de tipo 10 puede abrir una sesión confirmada y la asociación principal busca un flujo hacia el mismo host desde la misma IP, con inicio en la ventana [t − 15 s, t + 5 s]; si el evento aporta un puerto útil, exigimos coincidencia. Cuando quedan dos candidatos sin criterio de desempate, conservamos el estado ambiguo. Un 4625 de tipo 3 solo cuenta como candidato a RDP si existe un flujo TCP compatible, y un 1149 aislado queda como autenticación de red observada.

La vinculación entre sesiones y procesos recurre a host, época de arranque y LogonId efectivo, y privilegia TargetLogonId cuando existe y es válido para el sujeto del proceso. La relación entre LogonId y SessionId exige evidencia de la misma cuenta normalizada, del mismo host y de una ventana temporal común; una asociación sin clave suficiente queda pendiente. Sincronizamos los relojes con una fuente de tiempo en red (NTP) interna y, si la deriva supera los dos segundos, marcamos la fuente como degradada y posponemos el emparejamiento temporal automático.

Los eventos 4778 y 4779 corroboran la reconexión y la desconexión (Microsoft, 2021b). Los unificamos con LSM 25/24 cuando ya existe vínculo entre el Logon ID de Security y el identificador de sesión de LSM; sin ese vínculo preservamos ambos eventos.

Conservamos el canal y el registro original, porque la autenticación puede aparecer distribuida en varias entradas (Hastings et al., 2024). El vínculo calculado queda separado de la evidencia para que la correlación siga siendo revisable entre herramientas y resista registros incompletos (Azahari y Balzarotti, 2024; Chuah et al., 2025).

Gandhi et al. (2023) examinan la disponibilidad del registro de auditoría. Jiang et al. (2023) muestran la presión de productores intensivos sobre la auditoría. Se adoptan envío temprano, cola persistente, confirmación de recepción y prueba de interrupción CP-05.

Se adoptan ventanas y claves auditables. El contexto de procedencia ayuda a priorizar alertas (Hassan et al., 2019), y las manifestaciones de ataque sirven para interpretar secuencias de registros (Landauer et al., 2026). Se descarta un motor de grafos para esta fase por el costo de despliegue y evaluación (Bilot et al., 2025).

RF-06 conserva creación de procesos autorizados. Se descarta instrumentar eBPF o rastrear la ventana activa porque observarían otros niveles del sistema (Jin et al., 2025; Mahendrawathi et al., 2025). Sin señales de inyección y registro, 4688 tampoco acredita escalamiento (Bhardwaj et al., 2025).

La reconstrucción de decisiones de firewall muestra el riesgo de emplear campos que ya codifican la etiqueta de evaluación, y la evasión de reglas SIEM añade una razón para probar omisiones y cambios de formato. Mantenemos una etiqueta de escenario independiente y conservamos casos sin asociación para medir el efecto de los campos faltantes (Canay et al., 2026; Uetz et al., 2024).

7. DISEÑO DE INFRAESTRUCTURA

7.1. Servidores y equipos (hardware)

La Tabla 13 dimensiona el laboratorio.

Tabla 13

Dimensionamiento del laboratorio

Equipo	Rol	CPU	RAM	Disco	N.º
ADM-HV	Hipervisor Hyper-V	6 núcleos lógicos disponibles, VT-x/AMD-V y SLAT	32 GB instalados para cuatro VM	SSD con 250 GB libres antes de crear las VM	1
WIN-RDP	Host RDP, colector y sensor	2 vCPU	4 GB	65 GB	1
CLI-RDP	Pruebas normales y simulación	2 vCPU	4 GB	70 GB	1
ANL-RDP	API, datos y tablero	2 vCPU	4 GB	80 GB	1
FW-RDP	Enrutamiento y filtrado	1 vCPU	1 GB	12 GB	1

Nota. Elaboración propia.

Los 250 GB libres cubren 227 GB para discos de VM (70 + 65 + 80 + 12), 15 GB para puntos de control temporales y 8 GB para archivos auxiliares; los respaldos de 1 TB se contabilizan aparte. La comprobación de requisitos siguió las fichas publicadas de Windows 11 y de Hyper-V.

ADM-HV aloja las cuatro VM con 32 GB instalados: 13 GB para las VM (4 + 4 + 4 + 1), 6 GB de presupuesto para el anfitrión y Hyper-V y 13 GB de holgura. El comparable de 16 GB requiere un módulo adicional de 16 GB y una licencia Pro apta para Hyper-V. La edición y el módulo deben confirmarse con el equipo real.

El procesador suma 7 vCPU para las cuatro VM (2 + 2 + 2 + 1) sobre 6 núcleos lógicos: una sobreasignación de 1,17:1. Hyper-V la admite porque las VM del laboratorio no saturan su CPU al mismo tiempo, pero la contención debe medirse. CP-09 registra la espera de CPU del anfitrión y, si el

p95 de consulta supera la meta o la espera crece por encima del 10 %, ANL-RDP baja a 1 vCPU y FW-RDP conserva el suyo.

7.2. Sistemas operativos y software

La Tabla 14 fija las plataformas y su condición de licencia.

Tabla 14

Plataformas y software

Software	Versión de referencia	Función	Licencia y costo
Hyper-V	Windows 11 Pro	Virtualización y VLAN (red de área local virtual)	Incluido en el anfitrión licenciado
Windows Server	2022, Desktop Experience	Host RDP y auditoría	Licencia o evaluación autorizada
Windows 11 Pro	Compilación soportada del laboratorio	Cliente de RDP	Licencia disponible
Ubuntu Server	24.04 LTS	Análisis y firewall virtual	Distribución libre
PowerShell y TShark/Npcap	Windows PowerShell 5.1 y versiones compatibles probadas	Colector y captura	Revisar condiciones de Npcap y registrar versiones
Python, FastAPI y PostgreSQL	Python 3.12, PostgreSQL 16, FastAPI fijado al instalar	API, correlación y datos	Software de código abierto

Nota. Las fichas de soporte y las condiciones de licencia se registran en el Anexo L. Windows Server 2022 terminó su soporte principal el 14 de octubre de 2026 y permanece en soporte extendido hasta el 15 de octubre de 2031 (Microsoft, 2024b); la versión exacta de cada componente se fija antes de una eventual instalación. Se mantiene Windows Server 2022 porque el laboratorio dispone de licencia o evaluación autorizada y el soporte extendido cubre el horizonte del proyecto; Windows Server 2025 se evaluará cuando exista licencia institucional.

7.3. Almacenamiento y virtualización

Se usarán discos virtuales dinámicos con cuotas y control del espacio real. A una carga de referencia de 5 eventos/s y 1 KiB por evento, 30 días equivalen a aproximadamente 12,36 GiB de datos sin índices. Se presupuestan hasta 25 GiB para datos e índices bajo esa carga y se verificarán tamaño real, espacio de WAL y temporales. La carga de 50 eventos/s corresponde al ensayo de 10 minutos, mientras que 5 eventos/s es el supuesto para dimensionar retención.

El laboratorio conserva eventos, flujos y alertas durante 30 días; las copias diarias retienen 7 días y residen fuera del disco de análisis. El sistema advierte al llegar al 20 % de disco libre y pausa la captura diagnóstica antes de comprometer la base de datos. Las instantáneas facilitan restablecer escenarios y reciben un tratamiento distinto del respaldo verificable.

Se separan cliente y ejecución en cuatro VM, en vez de instalar la aplicación en cada terminal. La virtualización académica y la reutilización de equipos muestran antecedentes de esta separación (Marín Zúñiga, 2019; Martínez Urbina et al., 2007). Los proyectos de Terminal Server (Puchalt Rodríguez y Gómez García, 2014) y de gestión distribuida de laboratorios (Mosquera Asimbaya y Viñamagua Quezada, 2015) separan el cliente de la ejecución e inventarían cada nodo. El diseño adopta ambas prácticas en las cuatro VM y no copia sus cifras de dimensionamiento.

7.4. Servicios requeridos

El laboratorio requiere escritorio remoto, auditoría local, tareas de captura y reenvío, HTTPS, PostgreSQL, el trabajador de correlación, chrony y el registro de administración. Un proxy TLS inverso alojado en ANL-RDP (nginx, Tabla 9) separa ingesta.rdp.lab, que exige certificado de cliente, de monitor.rdp.lab, que autentica con sesión de usuario; ambos nombres internos apuntan a 10.20.30.10 y los resuelven las entradas de hosts del laboratorio. El colector usa certificados emitidos por una CA de laboratorio. La API publica contadores de lotes y de latencia, el trabajador expone su última ejecución y systemd inicia los servicios de análisis y de firewall (Figura 5).

Figura 5

Diagrama de despliegue



Nota. Elaboración propia.

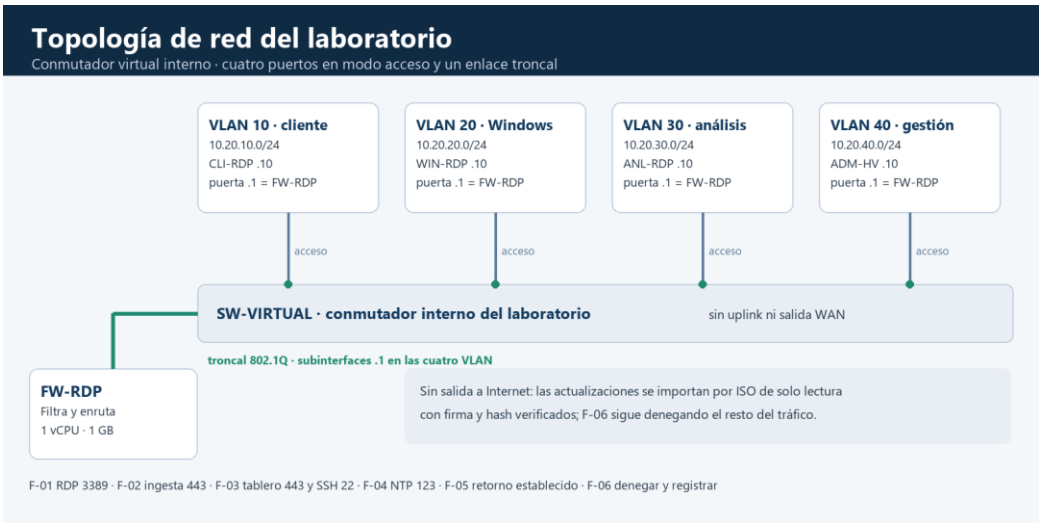
8. DISEÑO DE RED

8.1. Topología

Un conmutador virtual interno transporta los cuatro segmentos y el firewall virtual enruta entre ellos con denegación por omisión. La captura corre en la interfaz del servidor RDP y el anfitrión administra desde la VLAN 40. Durante las simulaciones, la red de práctica permanece sin salida general a Internet (Figura 6).

Figura 6

Topología de red del laboratorio



Nota. Elaboración propia.

8.2. Segmentación y VLAN

La VLAN 10 origina el tráfico RDP, la VLAN 20 aloja el host Windows, la VLAN 30 concentra análisis y tiempo y la VLAN 40 queda reservada para gestión. Cada VM usa una interfaz en modo acceso, salvo la VM firewall, cuya interfaz recibe las cuatro VLAN en modo troncal. No aplicamos NAT entre zonas internas, para preservar la IP de origen que observa el host.

8.3. Direccionamiento IP

La Tabla 15 asigna direcciones y VLAN a cada nodo.

Tabla 15

Asignación IPv4 y VLAN

Equipo	Segmento	IP	Máscara	Puerta de enlace
CLI-RDP	VLAN 10	10.20.10.10	/24	10.20.10.1
WIN-RDP	VLAN 20	10.20.20.10	/24	10.20.20.1
ANL-RDP	VLAN 30	10.20.30.10	/24	10.20.30.1
ADM-HV	VLAN 40	10.20.40.10	/24	10.20.40.1
FW-RDP	VLAN 10, 20, 30, 40	10.20.10.1, 10.20.20.1, 10.20.30.1 y 10.20.40.1	/24 por VLAN	Sin ruta WAN durante pruebas

Nota. Elaboración propia.

El direccionamiento pertenece al bloque privado 10.0.0.0/8 definido en el RFC 1918 (Rekhter et al., 1996). Los segmentos 10.20.10.0/24, 10.20.20.0/24, 10.20.30.0/24 y 10.20.40.0/24 son disjuntos, y cada uno admite 254 direcciones de host, con .1 reservada para el firewall y .10 asignada al nodo indicado. La dirección .0 identifica la red y .255 queda para difusión.

8.4. Reglas de firewall

La Tabla 16 define la política de filtrado entre zonas.

Tabla 16

Política de filtrado entre zonas

N.º	Origen	Destino	Puerto y protocolo	Acción
F-01	10.20.10.10	10.20.20.10	TCP y UDP 3389	Permitir RDP
F-02	10.20.20.10	10.20.30.10	TCP 443	Permitir ingesta con TLS mutuo (mTLS)
F-03	10.20.40.10	10.20.30.10	TCP 443 y 22	Permitir tablero y SSH con clave
F-04	10.20.10.10, 10.20.20.10 y 10.20.40.10	10.20.30.10	UDP 123	Permitir NTP interno
F-05	Conexiones establecidas o relacionadas	Origen correspondiente	Según estado	Permitir retorno
F-06	Cualquier otro origen	Cualquier destino	Cualquiera	Denegar y registrar con límite de tasa

Nota. El administrador gestiona WIN-RDP desde la consola de Hyper-V. F-03 restringe el acceso al anfitrión autorizado y F-06 bloquea toda salida no listada; las actualizaciones llegan por un medio verificado según §8.5.

8.5. Acceso remoto y sincronización horaria

El usuario abre la conexión desde el cliente autorizado y verifica el certificado del host. Todos los dispositivos se sincronizan con una referencia interna en UTC y su desviación queda registrada. El tablero muestra las horas convertidas a America/Lima y exporta en UTC con zona explícita; antes de cada corrida validamos conectividad, reglas y desfase. La referencia horaria es el anfitrión ADM-HV: antes de cada corrida su reloj se contrasta con el servicio institucional —o con un archivo de hora firmado que se importa por ISO de solo lectura cuando el laboratorio está aislado— y el desfase medido se anota en el acta. ANL-RDP sirve la hora al resto de las VM mediante chrony y la integración de Hyper-V mantiene sincronizados a los invitados; si chronyc tracking supera los dos segundos, la fuente se marca degradada y se pospone el emparejamiento automático.

RDP opera únicamente entre CLI-RDP y WIN-RDP. El switch interno carece de uplink y no habilitamos VPN de entrada; una futura ampliación institucional exigirá VPN con autenticación multifactor (MFA) y filtrado de origen antes de abrir acceso externo. Para actualizar el laboratorio descargamos los paquetes en un equipo separado, validamos firma y hash SHA-256, generamos un

manifiesto y los importamos mediante una ISO de solo lectura en Hyper-V. Probamos en una instantánea y registramos versión, operador y resultado; no abrimos ninguna excepción WAN.

9. DISEÑO DE SEGURIDAD

9.1. Riesgos y amenazas

La Tabla 17 valora y trata los riesgos identificados.

Tabla 17

Evaluación y tratamiento de riesgos

ID	Riesgo	P	I	P×I	Tratamiento	CSF / ISO A	Residual
S-01	Fuerza bruta contra WIN-RDP	2	3	6	NLA, restricción de origen y alerta	PR.AA / A.8.5	1×3=3
S-02	Movimiento lateral con cuenta válida	2	3	6	NLA, filtrado por origen, roles y segmentación por VLAN	PR.AA / A.8.22	1×3=3
S-03	Pérdida o alteración de evidencias	2	3	6	Confirmación, SHA-256 y copia 3-2-1	PR.DS / A.8.13	1×3=3
S-04	Exposición de identificadores	1	3	3	Seudónimos, MFA y permisos por rol	PR.DS / A.8.11	1×2=2
S-05	Asociación falsa por desfase	2	2	4	NTP y etiqueta de incertidumbre	DE.AE / A.8.17	1×2=2
S-06	Saturación del colector o disco	2	2	4	Cuotas, cola y alerta de capacidad	DE.CM / A.8.6	1×2=2
S-07	Regla permisiva o cambio en FW-RDP	2	3	6	Denegar por defecto y verificar F-01 a F-06	PR.IR / A.8.20	1×3=3
S-08	Caída de ANL-RDP o de PostgreSQL	2	3	6	Sondeo, reintento y restauración	RC.RP / A.8.13	1×3=3
S-09	Certificado mTLS vencido	2	2	4	Inventario y rotación de certificados	PR.DS / A.8.24	1×2=2
S-10	Cambios o borrado de logs de auditoría	2	3	6	Roles separados y bitácora de cambios	DE.CM / A.8.15	1×3=3
S-11	Caída o compromiso de FW-RDP	2	3	6	Reglas versionadas, imagen de referencia y restauración desde instantánea	PR.IR / A.8.20	1×3=3
S-12	Caída del anfitrión ADM-HV	1	3	3	Copia de VM y configuración fuera del anfitrión; reconstrucción documentada	RC.RP / A.8.13	1×3=3

Nota. Escala adaptada a partir de NIST SP 800-30 Rev. 1 y categorías del CSF 2.0.

Los residuales son estimaciones condicionadas a los controles y a la futura aceptación. El Anexo K explica, por riesgo, por qué cambia la probabilidad o el impacto, qué exposición subsiste y qué prueba puede refutar la valoración.

Anclas de la escala. Probabilidad: 1 = sin intentos observados en el periodo de referencia; 2 = al menos un intento en el trimestre; 3 = intentos repetidos o sostenidos en el mes. Impacto: 1 = reversible sin pérdida de evidencia ni de servicio; 2 = pérdida parcial restaurable dentro del RTO; 3 = exposición de credenciales, alteración de evidencia o interrupción no planificada. Con estas anclas dos analistas deben asignar el mismo valor al mismo riesgo, y el Anexo K indica la prueba que refuta cada valoración.

Limitamos el origen de RDP y exigimos NLA. El acceso remoto abierto aumenta la exposición (Multi-State Information Sharing and Analysis Center, 2019; Souppaya y Scarfone, 2016), y preferimos el filtrado por zonas a un perímetro definido por software, que añadiría un servicio al laboratorio (Rose et al., 2020; Ruambo et al., 2025). La guía conjunta respalda controlar el origen (Cybersecurity and Infrastructure Security Agency, National Security Agency, Federal Bureau of Investigation, Multi-State Information Sharing and Analysis Center, e Israel National Cyber Directorate, 2023). Excluimos los señuelos porque requieren una red de observación propia (Aung et al., 2025).

Actualizamos el host aun cuando use NLA: BlueKeep ilustra el riesgo previo a la autenticación (Yan y Chen, 2019). Los avisos de ransomware recomiendan limitar los servicios de acceso remoto (Cybersecurity and Infrastructure Security Agency, National Security Agency, Federal Bureau of

Investigation y Multi-State Information Sharing and Analysis Center, 2023; Federal Bureau of Investigation et al., 2024). El diseño registra señales de acceso y evita atribuir ransomware sin evidencia del host, como muestran los contextos distintos de LockBit y del RDP expuesto (Akinyemi et al., 2023; Vitla, 2024).

El análisis de riesgos adapta NIST SP 800-30 (Joint Task Force Transformation Initiative, 2012) y califica probabilidad (P) e impacto (I) de 1 a 3. El producto P×I indica nivel bajo (1–2), medio (3–4) o alto (6–9), y el residual emplea la misma escala después del tratamiento. El mapeo se refiere a CSF 2.0 y a ISO/IEC 27001:2022 Anexo A (International Organization for Standardization, 2022; National Institute of Standards and Technology, 2024).

Modelo de amenazas. Antes de valorar el riesgo se recorrió STRIDE sobre las cuatro zonas: suplantación (S-01, S-02), manipulación (S-03, S-10), repudio (bitácora de accesos y exportaciones), revelación de información (S-04), denegación de servicio (S-06) y elevación de privilegios (S-05, S-07), más el certificado vencido en el borde (S-09). Cada amenaza se asocia a la zona donde es posible y a un control de la Tabla 17; las que no admiten control en esta fase se declaran fuera de alcance en el §3.4. La Figura 7 ubica S-07 y S-09 en la zona de gestión porque el cambio de regla y la rotación del certificado se autorizan allí, aunque su efecto se manifieste en el borde.

9.2. Controles propuestos

F-01 limita el origen de RDP y WIN-RDP exige NLA, mientras CLI-RDP verifica el certificado TLS del servidor; la ingesta exige mTLS. En el tablero, Argon2id se combina con contraseñas de un solo uso basadas en tiempo (TOTP) para todos los roles, con límite de tasa, rechazo de reutilización y auditoría de los fallos de MFA. Las sesiones usan cookies HttpOnly, Secure y SameSite y los cambios de estado llevan protección contra falsificación de solicitud en sitios cruzados (CSRF). El diseño adapta segmentación y menor privilegio (Rose et al., 2020; Souppaya y Scarfone, 2016).

9.3. Gestión de accesos

El analista consulta y exporta según su rol; el administrador registra sensores y mantiene el servicio, y el responsable aprueba altas, cambios de reglas y la recuperación del segundo factor. Las semillas TOTP se cifran con una clave separada y desaparecen al revocar la cuenta, y cada alta y cada recuperación queda registrada. La interfaz de Figma representa la navegación y los escenarios. El acceso SSH a ANL-RDP se admite solo desde la VLAN 40, con clave pública ED25519 y sin contraseña ni reenvío de agente; cada clave se registra con titular y fecha, rota cada seis meses y se revoca al cambiar de responsable.

9.4. Respaldo y recuperación

Se ejecutará una copia lógica diaria con pg_dump en formato custom, cifrado y manifiesto SHA-256. La recuperación restaura primero en una base aislada, verifica integridad referencial, ejecuta consultas de control y registra el tiempo y la procedencia de la copia.

La exportación preserva procedencia e integridad (Guttman et al., 2022; Lyle et al., 2022). La adquisición selectiva reduce el volumen y la exposición frente a una copia forense completa (Aigbogun et al., 2026; Yu et al., 2024). El respaldo se limita a los campos de la Tabla 10 y conserva el contexto específico del acceso remoto (Manson, 2022).

La estrategia prevista mantiene tres copias: la base operativa, un respaldo cifrado en un medio removible y una segunda copia cifrada bajo custodia en una ubicación física distinta. Exige dos medios y conserva un manifiesto SHA-256, aunque la disponibilidad del medio externo y el lugar de custodia son supuestos del laboratorio. CP-07 restaurará desde una copia de respaldo y verificará la disponibilidad de la copia externa; el objetivo de punto de recuperación (RPO) ≤ 24 h y el objetivo de tiempo de recuperación (RTO) ≤ 2 h siguen siendo metas pendientes de medición. El administrador de TI custodia el medio removible y el responsable del sistema la copia externa; ambos verifican la legibilidad del manifiesto el primer día hábil de cada mes y anotan el resultado en el acta de mantenimiento.

9.5. Monitoreo y auditoría

La API audita inicios de sesión del tablero, exportaciones y cambios de reglas. El sistema observa edad del último evento, tamaño de cola, disco libre, errores de ingesta y desvío horario. Un cambio de

época o un evento de borrado de log dispara una alerta operativa y exige revisión. El tablero conserva actor, fecha, entidad y resultado para las operaciones autorizadas.

El modelo de riesgos conserva dos limitaciones declaradas: la escala ordinal no estima pérdidas esperadas ni frecuencias anualizadas, y el residual es una estimación condicionada a que los controles se verifiquen. Las anclas del §9.1 fijan el significado de cada valor —lo que reduce la dispersión entre analistas— y el Anexo K indica, por riesgo, la prueba que refutaría la valoración. La matriz ordena el tratamiento; no sustituye un análisis cuantitativo.

9.6. Privacidad y ética

La Ley N.° 29733 y su reglamento aprobado por el Decreto Supremo N.° 016-2024-JUS sirven de marco peruano para el tratamiento de datos personales (Congreso de la República del Perú, 2011; Ministerio de Justicia y Derechos Humanos, 2024). El prototipo usa cuentas ficticias, redes privadas y datos de laboratorio. Solo recoge los campos necesarios para asociar sesiones y excluye contenidos de pantalla, archivos y pulsaciones. La evaluación de usabilidad requiere informar a sus participantes y limitar el registro a tiempos y resultados. Un despliegue institucional requeriría evaluación de la finalidad, base jurídica, acceso y conservación por parte de la organización responsable. Véase la Figura 7.

Figura 7

Diagrama de seguridad



Nota. Elaboración propia. Los riesgos S-11 (caída o compromiso de FW-RDP) y S-12 (caída del anfitrión) son transversales a las cuatro zonas y se detallan en la Tabla 17.

10. DISEÑO DEL MOTOR DE DETECCIÓN Y PUNTUACIÓN DE RIESGO

10.1. Indicadores y reglas

La Tabla 18 define las reglas de detección y su peso.

Tabla 18

Reglas de detección

ID	Regla	Fuente	Puntos	Fundamento
R-01	≥ 5 fallos del mismo origen, cuenta y host en 5 min	4625 con contexto RDP	25	Microsoft (2021a)
R-02	Éxito en los 5 min posteriores a ≥ 5 fallos del mismo trío	4624 tipo 10 y 4625	30	T. Bai et al. (2019)
R-03	IP ausente del historial de la cuenta en los 14 días previos	4624 y evidencia de red	15	Souppaya y Scarfone (2016)
R-04	Éxito fuera del horario autorizado configurado	4624 y calendario	10	Souppaya y Scarfone (2016)
R-05	Privilegios especiales asociados al mismo inicio	4672 y LogonId	15	Microsoft (2021a)

ID	Regla	Fuente	Puntos	Fundamento
R-06	Una cuenta inicia desde ≥ 3 IP distintas en 15 min	4624 tipo 10	15	T. Bai et al. (2019)
R-07	≥ 8 fallos hacia ≥ 5 cuentas desde una IP en 10 min	4625 con contexto RDP	55	MITRE (2026a)

Nota. Elaboración propia.

Los valores son hipótesis de diseño y quedan documentados por versión. R-03 permanece deshabilitada mientras el historial sea insuficiente, y el historial de pruebas puede precargarse con datos sintéticos marcados para que la regla resulte reproducible desde el primer ensayo.

Nuestra R-01 exige fallos en Windows además de recurrencia en la red (Hornyák, 2022; Vizváry y Vykopal, 2013), y R-07 modela la dispersión hacia varias cuentas, tal como describe MITRE (2026a). El umbral de 8 fallos, 5 cuentas y 10 minutos es una hipótesis local. Rose et al. (2020) fundamentan los controles de acceso y segmentación del §9, mientras que MITRE (2026b) sostiene tratar la cuenta válida como indicio separado.

Preferimos señales de cuenta, origen y tiempo antes que entrenar un modelo con una muestra pequeña. Los trabajos de T. Bai y colaboradores estudian el movimiento lateral mediante RDP (T. Bai et al., 2019; T. Bai et al., 2021). La tesis de Z. Bai (2019) orienta la elección de atributos, aunque no cuenta como réplica independiente. Los intentos se corroboran con eventos de Windows, porque una conexión por sí sola no prueba movimiento lateral (Dora y Hluchý, 2026; Meijerink, 2019).

Las reglas separan tres señales: el horario, la rareza del origen y la relación entre cuenta y equipo. El perfil temporal y la rareza aportan información distinta (Chapple et al., 2007; Radah et al., 2023). Los métodos que modelan cambios estructurales en el historial de autenticación ofrecen un antecedente de investigación (Siadati y Memon, 2017). El diseño actual aplica reglas explicables con la evidencia disponible.

10.2. Puntuación 0–100 y umbrales

Puntaje = mín(100, mín(50, R-01 + R-02) + R-03 + R-04 + R-05 + R-06 + R-07). Cada R-n aporta su peso si la condición se cumple y cero en caso contrario. Se limita la suma de R-01 y R-02 porque el mismo bloque de fallos contribuye a ambas reglas. El puntaje es ordinal. Un valor de 80 identifica prioridad crítica en esta configuración, sin interpretarse como una probabilidad del 80 %. La Tabla 19 traduce el puntaje en severidad y acción.

Tabla 19

Severidad del puntaje

Puntaje	Severidad	Acción
0–24	Baja	Registrar y conservar contexto.
25–49	Media	Revisar en cola según recurrencia.
50–74	Alta	Abrir alerta con evidencia y revisar durante la práctica.
75–100	Crítica	Priorizar revisión y confirmar el alcance antes de contener.

Nota. Elaboración propia.

10.3. Clasificación de conexiones

Cada conexión recibe etiquetas acumulables: actividad habitual, posible fuerza bruta, posible password spraying, credencial por verificar, acceso fuera de horario y posible movimiento lateral. Los patrones de autenticación aportan, por sí solos, señales preliminares. Un indicio compatible con ransomware queda registrado únicamente como hipótesis del analista, respaldada por evidencia externa al motor de esta unidad. Las etiquetas y la decisión humana se mantienen separadas del puntaje calculado.

10.4. Alerta explicable

El caso sintético AL-018 ilustra el cálculo. La cuenta lab-07 inicia en WIN-RDP desde 10.20.10.10 después de cinco fallos; el origen es nuevo en el historial de prueba, la sesión empieza fuera del horario autorizado y el evento 4672 acompaña al mismo LogonId. R-01 y R-02 aportan 50 puntos tras el tope, R-03 suma 15, R-04 suma 10 y R-05 suma 15: el total es 90/100, crítico. El detalle identifica la

ventana, los cinco fallos, el éxito y el privilegio, y el analista comprueba si la cuenta tenía autorización para ese origen y ese turno.

10.5. Aprendizaje automático (trabajo futuro)

Un estudio posterior podrá comparar las reglas con modelos supervisados a partir de un corpus autorizado, con casos representativos y separación temporal de entrenamiento y prueba. Se medirán falsos positivos, estabilidad ante cambios del entorno y explicabilidad. El diseño base de la Unidad III usa reglas y deja el conjunto de datos etiquetado como insumo.

Se priorizan reglas reproducibles. Los hipergrafos y la detección en nube dependen de datos de otros entornos (Attou et al., 2023; He et al., 2026). Los modelos de ransomware necesitan trazas etiquetadas de eventos Windows o Sysmon (Ispahany et al., 2025; Nashivochnikov et al., 2025). La inferencia en memoria requiere adquisición fuera del alcance de RF-06 (Sanjalawe et al., 2026).

11. DISEÑO DE LA INTERFAZ Y PROTOTIPO

11.1. Mapa de navegación

La navegación parte de Inicio de sesión y avanza por Resumen, Conexiones y Detalle de sesión; desde Resumen el analista llega a Alertas, Detalle de alerta y Evidencia. Reportes conserva los filtros al exportar y Reglas queda disponible solo para el responsable del sistema. El rango temporal elegido acompaña al analista durante todo el recorrido.

11.2. Pantallas del prototipo

La Tabla 20 describe las vistas del prototipo.

Tabla 20

Vistas del prototipo

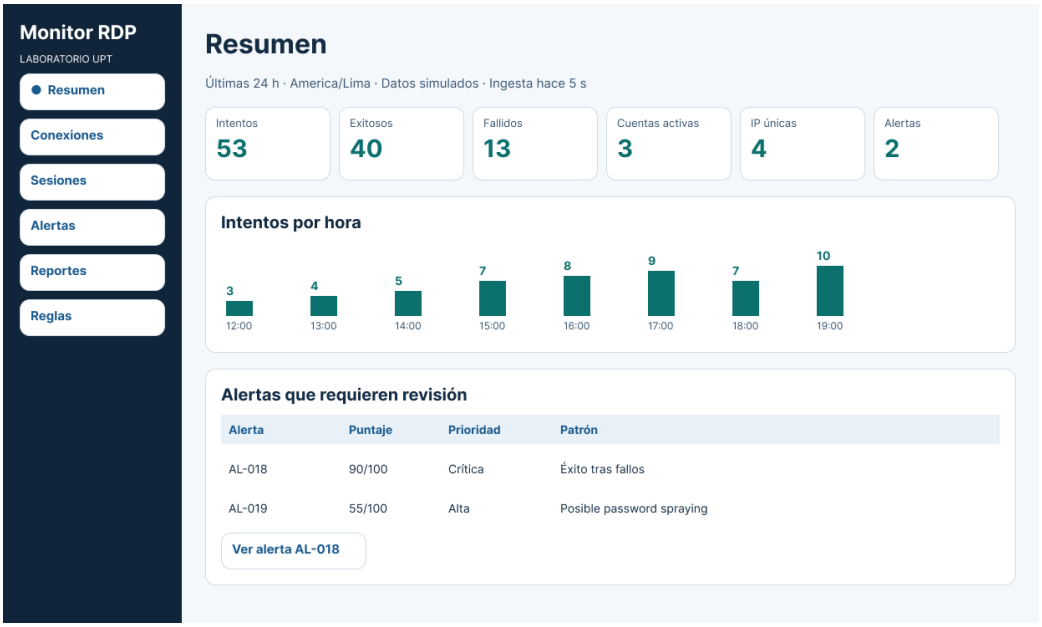
Pantalla	Propósito	Rol	Datos mostrados
Inicio de sesión	Autenticar	Todos	Usuario y estado de acceso.
Resumen	Vigilar el laboratorio	Analista y TI	Intentos RDP, éxitos, fallos, cuentas activas, IP únicas, alertas y frescura.
Conexiones	Filtrar intentos	Analista	Fecha, origen, cuenta, host, resultado, confianza.
Sesión y cronología	Reconstruir la sesión	Analista	Estado, intervalos activos, evidencias y ejecutable permitido.
Alertas y detalle	Explicar el puntaje	Analista	Riesgo, reglas, evidencias, motivos y estado de revisión.
Reportes	Exportar selección	Analista	Rango, filtros, recuento y CSV.
Reglas	Revisar parámetros	Responsable	Versiones, ventanas, pesos, umbrales y auditoría.

Nota. Elaboración propia.

El resumen cuenta intentos únicos ya clasificados, calcula las cuentas activas sobre sesiones en estado activo y obtiene las IP únicas de los intentos del intervalo seleccionado. Los eventos sin asociación y el atraso de las fuentes aparecen por separado, y todas las pantallas usan datos ficticios de demostración (Figura 8).

Figura 8

Prototipo del dashboard en Figma



Nota. Captura del prototipo propio en Figma con datos simulados.

11.3. Enlace al prototipo y criterios de usabilidad

Abrir el archivo editable de Figma

Abrir el recorrido del analista

El recorrido de diseño verificó la representación de tres casos simulados: AL-018 muestra 90/100 y motivos; CD-02 muestra la sesión normal y 0/100; CD-03 conserva dos flujos y deja pendiente su asociación. El Anexo J enlaza cada caso con requisitos, entradas, reglas, vista y criterio de aceptación. CP-08 conserva el objetivo futuro de que 4 de 5 participantes identifiquen la evidencia en dos minutos. Abrir Casos de diseño en Figma

12. DISEÑO OPERATIVO

12.1. Roles y responsabilidades (RACI)

Matriz RACI (responsable, aprobador, consultado, informado). R = ejecuta. A = aprueba y responde por la actividad. C = participa en la revisión. I = recibe el resultado. Cada actividad tiene un suplente nombrado: si Mattias no está, Piere asume arquitectura y acceso RDP; si Fabiana falta en la semana 14, Dana ejecuta el tablero y la exportación. La asignación parte de los seis subtemas del equipo y se revisa al inicio de cada semana de trabajo (Tabla 21).

Tabla 21

Matriz de responsabilidades RACI

Actividad	Piere	Dorian	Mattias	Dana	Fabiana	Leonel
Arquitectura y acceso RDP	C	C	A/R	I	I	C
Red, captura y escenarios	C	A/R	C	C	I	C
Colector y correlación	C	C	A	C	I	R
Controles y respuesta	A/R	C	C	C	I	C
Tablero, reportes y usabilidad	I	I	A	C	R	C
Reglas y evaluación	C	C	A	R	C	C
Integración y sustentación	R	R	A/R	R	R	R

Nota. Elaboración propia.

12.2. Procedimientos de operación

Cada corrida tiene un operador designado —Mattias, Dorian o Leonel, en rotación— y un analista. El operador comprueba el aislamiento (Get-VMSwitch SW-VIRTUAL, sin adaptador físico asociado), el reloj (w32tm /query /status en WIN-RDP y chronyc tracking en ANL-RDP), la auditoría (auditpol /get /category:*), la interfaz de captura (tshark -D), la ingesta (curl --cacert /etc/ssl/ca-lab.crt https://10.20.30.10/health) y la frescura de las fuentes, y anota cada resultado en el acta. Cada paso tiene contingencia: un adaptador físico en el conmutador obliga a detener la corrida y recrearlo; un desfase mayor de 2 s se corrige con w32tm /resync o reiniciando chrony; si auditpol no muestra las dos subcategorías se habilitan y se reinicia la sesión; si tshark no enumera la interfaz se reinstala Npcap y se registra el cambio; si la ingesta no responde se revisan F-02 y el certificado de cliente. El analista confirma la llegada de los eventos y, al cerrar, deshabilita la cuenta con Disable-LocalUser.

12.3. Procedimientos de mantenimiento

Cada sesión incluye una revisión de reloj, cola, espacio libre y vigencia de certificados. El administrador comprueba con Get-WinEvent -ListLog Security que el registro no rota antes de la ingesta, consulta df -h y el tamaño de la base en ANL-RDP y revisa systemctl status del trabajador. Todo cambio queda registrado con versión, motivo y responsable y se aplica primero en una instantánea de ensayo. Contingencia: si Security rota antes del envío, se amplía MaximumSizeInBytes y se prioriza el reenvío pendiente; si el disco baja del 20 %, se pausa la captura diagnóstica y se depuran las instantáneas antiguas; si una actualización rompe una consulta, se revierte la versión y se conserva el registro del fallo.

12.4. Gestión de incidentes

El analista abre la alerta, identifica la regla, verifica los eventos asociados y revisa los registros que quedaron fuera de la correlación. El protocolo adapta NIST SP 800-61 Rev. 3 (Nelson et al., 2025) y fija dos plazos para la práctica: quince minutos para el triaje y dos horas para la decisión de contención. Si el responsable no responde en ese plazo, el analista bloquea el origen con una regla temporal F-TMP en FW-RDP y registra la medida como provisional. Confirmado el patrón, el responsable autoriza deshabilitar la cuenta, bloquear el origen o detener el escenario, y el administrador ejecuta el cambio, verifica el restablecimiento y entrega al analista las marcas de tiempo. Cuando el caso resulta benigno se documenta la razón y se evalúa la regla en una nueva versión.

La contención afecta solo a las VM de práctica. Antes de revertir cualquier instantánea, el equipo preserva la evidencia autorizada junto con su manifiesto.

13. PLAN DE IMPLEMENTACIÓN (UNIDAD III)

13.1. Actividades, recursos y dependencias

La Tabla 22 reparte actividades, recursos y dependencias.

Tabla 22

Actividades de la Unidad III

Actividad	Recursos	Dependencia	Responsable	Semana
Preparar entorno, VLAN, firewall y relojes	PC y cuatro VM	Licencias y asignación de recursos	Mattias, Dorian y Piere	9
Instrumentar eventos y captura	Windows, Npcap, TShark	Entorno aislado y configuración de auditoría	Leonel y Dorian	10
Ingesta, almacenamiento y correlación	FastAPI y PostgreSQL	Esquemas y muestras de eventos	Leonel y Mattias	11–12
Reglas, alerta y revisión	Trabajador y casos sintéticos	Correlación y ventanas verificadas	Dana y Piere	12–13

Actividad	Recursos	Dependencia	Responsable	Semana
Tablero, exportación y roles	API y diseño de interfaz	Consultas de conexiones y alertas	Fabiana y Mattias	13–14
Pruebas, ajustes y sustentación	Matriz CP-01 a CP-09	Integración completa	Equipo	14–15

Nota. Elaboración propia.

Cada fase tiene una condición de terminado. La fase de entorno exige conectividad permitida y rechazos previstos por VLAN. La instrumentación exige el mismo evento en origen e ingesta con su identificador. La integración exige reconstruir una sesión y conservar un caso ambiguo. La fase de reglas exige reproducir el puntaje de los casos de referencia. La fase de interfaz exige navegación y CSV con roles distintos. La validación termina con la matriz CP-01 a CP-09, los resultados y un registro de incidencias firmado por el responsable.

13.2. Cronograma

La Tabla 23 muestra el Gantt por semana.

Tabla 23

Gantt de la eventual implementación por semana

Hito	S9	S10	S11	S12	S13	S14	S15
H1 Entorno y conectividad	■						
H2 Instrumentación (dep. H1)		■					
H3 Ingesta y correlación (dep. H2)			■	■			
H4 Detección y alertas (dep. H3)				■	■		
H5 Interfaz y exportación (dep. H3)					■	■	
H6 Pruebas y sustentación (dep. H4/H5)						Preprueba s	Aceptación

Nota. Elaboración propia. H4 puede iniciar cuando se congela el contrato de ingesta en H3. H6 prepara y ejecuta prepruebas en S14. La aceptación integrada se realiza en S15, tras completar H4 y H5. La ruta de cierre sigue H1, H2, H3, H5 y H6, con H4 como dependencia paralela.

Toda modificación a un componente aprobado exige solicitud de cambio, análisis de impacto técnico, trazabilidad y decisión del equipo. La semana 16 queda reservada al calendario institucional, y cada responsable conserva las capturas, las configuraciones y los resultados de sus propias actividades.

14. PLAN DE PRUEBAS

14.1. Estrategia

El plan propone 20 escenarios normales y 20 de ataque simulado en una red aislada. La unidad de evaluación de detección será el escenario etiquetado. Se fija de antemano el esperado, el intervalo, la IP, la cuenta y el host. Se separan los casos usados para ajustar reglas de los 40 casos de validación. El equipo conservará la versión de configuración y el resultado de cada caso para facilitar la repetición.

La batería incluye accesos correctos, fallos aislados benignos, reconexión y cierre, fuerza bruta de prueba y password spraying controlado, y añade casos de degradación, reinicio de un colector y concurrencia con origen compartido. Las reglas que exigen varios orígenes se verifican mediante reproducción controlada de registros sintéticos, diferenciada de las corridas con tráfico real.

14.2. Casos de prueba

La Tabla 24 resume los casos, sus criterios de aceptación y el estado de cada comprobación.

Tabla 24

Casos de prueba, criterios y estado

ID	Qué se prueba	Cómo	Resultado esperado	Criterio de aceptación	Estado
CP-01	Eventos y flujo	Arrancar, conectar y cerrar en Windows.	Se preservan host, reloj y procedencia.	Identificadores y extremos coinciden con la bitácora.	Planificado para la Unidad III.
CP-02	Ciclo de sesión	Conectar, desconectar, reconectar y cerrar.	Reconstrucción con intervalos activos.	Todas las transiciones esperadas se reflejan.	Planificado para la Unidad III.
CP-03	Proceso y ambigüedad	Abrir ejecutable permitido y reproducir dos flujos compatibles.	El proceso fiable se vincula y el empate queda pendiente.	Cero asociaciones falsas en ambos casos controlados.	Ambigüedad sintética comprobada. Asociación de proceso pendiente.
CP-04	Motor de reglas	Reproducir escenarios etiquetados, incluido el ejemplo AL-018.	Detección y puntaje reproducibles.	Detección ≥ 90 %, falsos positivos ≤ 10 %, AL-018 = 90.	Puntuación sintética validada (Anexo O). Métricas de detección pendientes.
CP-05	Cola y carga	Cortar HTTPS 10 min a 50 eventos/s y restablecer.	Reenvío completo e idempotente.	30 000 eventos únicos en ≤ 30 min desde el inicio del corte, sin pérdida ni duplicados.	Planificado para la Unidad III.
CP-06	Roles y auditoría	Probar MFA válido, ausente y reutilizado. Revisar roles y exportación.	Se rechaza acceso indebido y se audita exportación.	Cero accesos con MFA inválido o fuera del rol. Exportación auditada.	Planificado para la Unidad III.
CP-07	Recuperación	Restaurar copia en base aislada y revertir una regla.	Datos y versión recuperados.	RPO ≤ 24 h, RTO ≤ 2 h y puntaje previo reproducido.	Planificado para la Unidad III.
CP-08	Usabilidad	Cinco participantes ejecutan la tarea de investigación.	Encuentran motivos y evidencia.	Al menos 4 de 5 completan la tarea en ≤ 2 min.	Planificado para la Unidad III.
CP-09	Rendimiento	Carga de 50 eventos/s por 10 min con HTTPS disponible.	Tablero y consultas responden dentro del objetivo.	Disponibilidad ≥ 99 %; p95 extremo a extremo ≤ 20 s y p95 consulta ≤ 2 s, sin pérdida.	Planificado para la Unidad III.

Nota. Elaboración propia.

El Anexo E enlaza requisitos, casos y evidencia de aceptación. Cada corrida registrará versión, identificador, entrada, resultado esperado, resultado observado y dictamen. La etiqueta del escenario se fija antes de ejecutar la prueba.

14.3. Métricas de evaluación

En la Unidad III se calcularán la detección como VP/(VP + FN), la tasa de falsos positivos como FP/(FP + VN) y la precisión como VP/(VP + FP). Un escenario positivo se contará como detectado si la alerta coincide con la evidencia esperada y supera el umbral del patrón. De 20 escenarios positivos se esperan al menos 18 detecciones. De 20 escenarios normales se admiten hasta dos falsos

positivos. Se informarán los conteos, los denominadores nulos y el intervalo de confianza de Wilson al 95 % para la detección.

Se calculará la cobertura sobre los intentos con evidencia suficiente y se informarán por separado los eventos ambiguos y los que queden sin par. La latencia del tablero se medirá desde la evidencia calificante hasta su primera visualización. El p95 de consulta se calculará con solicitudes repetidas sobre el mismo volumen y rango. CP-08 comprobará la usabilidad del tablero frente al criterio de aceptación de la Tabla 24.

La disponibilidad equivale a 100 × sondeos HTTPS exitosos / sondeos esperados. CP-09 programará un sondeo cada 5 s durante 10 min desde ADM-HV y exigirá un mínimo de 119 respuestas válidas de 120. CP-05 verificará por separado la recuperación de 30 000 eventos tras el corte deliberado.

14.4. Evidencia del diseño y validación prevista

La evidencia del diseño comprende el prototipo navegable de Figma y tres escenarios simulados (Anexo J). El recorrido muestra el acceso normal, la alerta AL-018 y el tratamiento de una asociación ambigua.

La implementación y la validación integral se realizarán en la Unidad III mediante los casos de la Tabla 24. La Tabla 25 precisa cómo se verificará la adquisición de eventos y flujos como parte de CP-01, CP-02 y CP-03. El Anexo M sirve como referencia técnica para la instrumentación.

El Anexo O conserva siete comprobaciones de puntuación con datos sintéticos. AL-018 obtuvo 90/100, el acceso normal obtuvo 0/100 y el caso ambiguo quedó pendiente. El Anexo Q conserva la captura y los eventos que documentan el problema de relacionar las dos fuentes.

Tabla 25

Verificación de la adquisición en la Unidad III

Criterio	Condición de aceptación	Caso y evidencia
Eventos de autenticación	Identificar un 4624 tipo 10 y un 4625 con contexto RDP en el escenario correspondiente.	CP-01. Registros de Security y bitácora de la prueba.
Captura de red	Localizar un flujo compatible por cada intento documentado.	CP-01. Captura y lista de flujos con origen, destino y hora.
Desfase entre VM	Diferencia de ≤ 2 s contra la misma referencia.	CP-01. Registro de sincronización y marcas de tiempo.
Ciclo de sesión	Corroborar 4778 y 4779 con LSM 25 y 24 mediante sesión y ventana.	CP-02. Secuencia de transiciones respaldada por ambos canales.
Asociación intento–flujo	Cotejar host, origen, hora y puerto si consta. Conservar como pendiente el vínculo ambiguo.	CP-03. Lista de candidatos y motivo del dictamen.
Integridad	Comprobar los archivos registrados en el manifiesto SHA-256.	CP-01. Manifiesto y resultado de la verificación.

Nota. Elaboración propia. Las verificaciones forman parte de los casos de aceptación de la Tabla 24.

15. ANÁLISIS DE FACTIBILIDAD

15.1. Factibilidad técnica

Los componentes permiten separar captura, procesamiento y presentación en un único laboratorio. La viabilidad depende de acceso a virtualización, auditoría del host, instalación autorizada del controlador de captura y certificados. La primera semana técnica debe verificar estos prerrequisitos. Se recomienda medir espacio real por evento y comprobar el efecto de la captura en CPU antes de ampliar el número de fuentes.

15.2. Factibilidad económica

La Tabla 26 resume inversión, operación y costo de propiedad.

Tabla 26

Inversión, operación y costo de propiedad

Clase	Concepto y alcance	Monto o estado
CAPEX incremental	Dos discos Seagate de 1 TB, S/ 239,00 cada uno	S/ 478,00

Clase	Concepto y alcance	Monto o estado
Aporte en especie	Anfitrión comparable Lenovo con 16 GB de fábrica. Ampliación presupuestada a 32 GB. Confirmar Windows 11 Pro.	S/ 3 699,00 de reposición base
Ampliación RAM	Un módulo adicional de 16 GB DDR5 SO-DIMM. Confirmar compatibilidad.	S/ 1 492,00 referencial
Licencia comercial	Windows Server 2022 Standard, OEM de 16 núcleos (P73-08338), con IGV; precio público consultado el 9/11/2026 en Techpoint Perú	S/ 3 730,81 (solo si no hay licencia institucional ni evaluación)
OPEX de entrega	Impresión, anillado y presentación; supuesto del equipo	S/ 80,00
OPEX a 12 meses	192 kWh/año. Electricidad al supuesto de S/ 0,90/kWh. Soporte y traslado pendientes.	S/ 172,80 de energía como escenario; otras partidas pendientes.
Subtotal incremental	Discos, entrega y ampliación de RAM. Reserva de S/ 20 separada.	S/ 2 050,00 antes de energía
Escenario incremental a 12 meses	S/ 2 050,00 + S/ 172,80. Licencias, soporte y envío pendientes.	S/ 2 222,80 parcial
Escenario con licencia comercial	Subtotal de S/ 2 050,00 + energía de S/ 172,80 + licencia de S/ 3 730,81	S/ 5 953,61

Nota. Elaboración propia. El Anexo L registra fuentes, precios públicos, supuestos y partidas pendientes. Confirmar compatibilidad, vigencia y envío antes de comprar.

Dos medios de 1 TB cubren siete copias estimadas de 25 GiB por medio. El comparable de S/ 3 699,00 valoriza el equipo base, y el módulo DDR5 SO-DIMM Kingston de 16 GB mantiene un precio público referencial de S/ 1 492,00, sujeto a compatibilidad, stock y envío.

El escenario incremental suma S/ 2 222,80: discos S/ 478,00, entrega S/ 80,00, memoria S/ 1 492,00 y energía S/ 172,80 (192 kWh × S/ 0,90). El precio de la energía es un supuesto de sensibilidad que debe contrastarse con el recibo y con el pliego vigente de Electrosur. Si el laboratorio carece de licencia institucional y deja de usar la evaluación de 180 días, el escenario sube a S/ 5 953,61 con la licencia OEM cotizada el 9 de noviembre de 2026. La reserva de S/ 20,00 se informa aparte.

Análisis de sensibilidad. La energía es el único supuesto con margen real: ±20 % sobre S/ 172,80 mueve el subtotal entre S/ 2 188,24 y S/ 2 257,36. La memoria es la partida dominante: si el equipo base ya incorpora 32 GB, el escenario baja a S/ 730,80 y la ampliación desaparece del CAPEX. El diseño no calcula VAN ni TIR porque el laboratorio no genera ingresos: el criterio de decisión es el costo incremental.

TCO a tres años y umbral de nube. El costo de propiedad a 36 meses es S/ 2 568,40 sin licencia comercial (S/ 2 050,00 de CAPEX incremental + 3 × S/ 172,80 de energía) y S/ 6 299,21 con la licencia OEM. Como el laboratorio no genera ingresos, la comparación se hace por costo mensual equivalente: S/ 71,34 y S/ 174,98 respectivamente. Una alternativa en nube para tres VM equivalentes solo sería preferible si su cotización mensual, con salida de datos y retención de 30 días, quedara por debajo de ese umbral; la cotización formal queda pendiente y se incorporará al Anexo L.

15.3. Factibilidad operativa

El equipo de seis integrantes cubre las actividades con un suplente por área, y una corrida puede ejecutarse con dos personas: un operador y un analista. La operación inicial exige tres horas semanales —una para el arranque y la corrida, una para el análisis y una para el mantenimiento—, y el procedimiento de arranque, la guía de investigación y el procedimiento de recuperación permiten que otra persona reproduzca la corrida. Riesgo aceptado: la rotación de integrantes puede retrasar una semana la revisión de reglas, y la mitigación es el suplente nombrado en §12.1 junto con el registro de aprobaciones, versiones y cambios.

16. CONCLUSIONES Y RECOMENDACIONES

16.1. Conclusiones

El diseño responde a los cuatro objetivos específicos en el grado que permite una unidad de diseño, con la validación que se pudo ejecutar dentro del plazo.

OE-01. La evidencia mínima quedó especificada: campos del evento normalizado (Tabla 10), eventos de Windows a recolectar (Tabla 12) y reglas de asociación que conservan procedencia, reloj y estado de calidad.

OE-02. La asociación se definió en la ventana [t − 15 s, t + 5 s], con estados confirmado, pendiente y sin asociación, y con conservación de ambos candidatos cuando no existe criterio de desempate.

OE-03. Los tres casos de Figma reproducen AL-018 con 90/100, el acceso normal con 0/100 y la asociación ambigua pendiente, y el motor de reglas reproduce esos valores en siete casos sintéticos (Anexo O).

OE-04. Se entregan cuatro diagramas, seis reglas de filtrado y una matriz de doce riesgos con criterios de aceptación (Tabla 17 y Anexo K).

Limitaciones. El antecedente documental describe la evidencia disponible en una captura del laboratorio. El prototipo representa escenarios simulados y el motor se comprobó con datos sintéticos. La ingesta, el ciclo completo de sesión, la asociación de eventos con flujos y las métricas de rendimiento se verificarán mediante el plan de aceptación de la Unidad III.

16.2. Recomendaciones

En la Unidad III se implementará el diseño y se ejecutarán los casos de aceptación de la Tabla 24. Como trabajo futuro, se podrá estudiar el efecto del tablero en el tiempo de investigación mediante una comparación de tareas equivalentes con y sin la herramienta.

REFERENCIAS BIBLIOGRÁFICAS

Aigbogun, O. O., Varol, C., & Shashidhar, N. (2026). A layered high-value evidence area (HVEA) model for selective Windows digital forensics imaging: NIJ-aligned design and empirical validation. *Electronics, 15*(14), Artículo 3024. https://doi.org/10.3390/electronics15143024

Akinyemi, O., Sulaiman, R., & Abosata, N. (2023). *Analysis of the LockBit 3.0 and its infiltration into Advanced's infrastructure crippling NHS services* [Prepublicación]. arXiv. https://doi.org/10.48550/arXiv.2308.05565

Amoretti, A. (2025). *Implementation and testing of an open source NDR solution* [Tesis de maestría, Politecnico di Torino]. WebThesis. https://webthesis.biblio.polito.it/37915/

Archila Morán, M. A. (2024). *Aplicación de técnicas de análisis forense en paquetes de redes domésticas sospechosos para confirmar la presencia de intrusos* [Trabajo de graduación, Universidad del Valle de Guatemala]. Repositorio Institucional de la Universidad del Valle de Guatemala. https://repositorio.uvg.edu.gt/entities/publication/cb67ce6a-aae1-45ea-8cf4-c97c8ecd11eb/full

Arellano-Uson, J., Magaña, E., Morató, D., & Izal, M. (2021). Protocol-agnostic method for monitoring interactivity time in remote desktop services. *Multimedia Tools and Applications, 80*(13), 19107–19135. https://doi.org/10.1007/s11042-021-10708-3

Atanassov, A., Baun, C., & Bouché, J. (2024). Grenzen verschiedener Betriebssysteme und Endgeräte überwinden durch neuartiges Desktop-as-a-Service [Superar las barreras entre sistemas operativos y dispositivos mediante un nuevo escritorio como servicio]. *Informatik Spektrum, 47*(5–6), 153–162. https://doi.org/10.1007/s00287-024-01583-x

Attou, H., Mohy-eddine, M., Guezzaz, A., Benkirane, S., Azrour, M., Alabdultif, A., & Almusallam, N. (2023). Towards an intelligent intrusion detection system to detect malicious activities in cloud computing. *Applied Sciences, 13*(17), Artículo 9588. https://doi.org/10.3390/app13179588

Aung, Y. L., Khoo, Y. L., Zheng, D. Y., Duo, B. S., Chattopadhyay, S., Zhou, J., Lu, L., & Goh, W. (2025). *HoneyWin: High-interaction Windows honeypot in enterprise environment* [Prepublicación]. arXiv. https://doi.org/10.48550/arXiv.2505.00465

Azahari, A., & Balzarotti, D. (2024). On the inadequacy of open-source application logs for digital forensics. *Forensic Science International: Digital Investigation, 49*, Artículo 301750. https://doi.org/10.1016/j.fsidi.2024.301750

Bai, T., Bian, H., Abou Daya, A., Salahuddin, M. A., Limam, N., & Boutaba, R. (2019). A machine learning approach for RDP-based lateral movement detection. En *2019 IEEE 44th Conference on Local Computer Networks (LCN)* (pp. 242–245). IEEE. https://doi.org/10.1109/LCN44214.2019.8990853

Bai, T., Bian, H., Salahuddin, M. A., Abou Daya, A., Limam, N., & Boutaba, R. (2021). RDP-based lateral movement detection using machine learning. *Computer Communications, 165*, 9–19. https://doi.org/10.1016/j.comcom.2020.10.013

Bai, Z. (2019). *A machine learning approach for RDP-based lateral movement detection* [Tesis de maestría, University of Waterloo]. UWSpace. https://uwspace.uwaterloo.ca/items/59fd9857-54a8-495c-8384-6e7176f73610

Bhardwaj, A., Sapra, L., & Rahman, S. (2025). Elasticsearch-based threat hunting to detect privilege escalation using registry modification and process injection attacks. *Future Internet, 17*(9), Artículo 394. https://doi.org/10.3390/fi17090394

Bilot, T., Jiang, B., Li, Z., El Madhoun, N., Al Agha, K., Zouaoui, A., & Pasquier, T. (2025). Sometimes simpler is better: A comprehensive analysis of state-of-the-art provenance-based intrusion detection systems. En *Proceedings of the 34th USENIX Security Symposium* (pp. 7193–7212). USENIX Association. https://www.usenix.org/conference/usenixsecurity25/presentation/bilot

Canay, Ö., Özkurt, C., & Garri, F. (2026). *Near-deterministic reconstruction of enterprise firewall decisions for policy audit: Proxy structure, context shift, and residual uncertainty* [Prepublicación]. Research Square. https://doi.org/10.21203/rs.3.rs-10586406/v1

Chapple, M. J., Chawla, N., & Striegel, A. (2007). Authentication anomaly detection: A case study on a virtual private network. En *MineNet'07: Proceedings of the Third Annual ACM Workshop on Mining Network Data* (pp. 17–22). Association for Computing Machinery. https://doi.org/10.1145/1269880.1269886

Chuah, E., Kalutarage, H., Tasdemir, K., Abrham, A., & Maple, C. (2025). A systematic literature review of log-correlation tools for cyberattack detection and prediction in large networks. *Journal of Information Security and Applications, 92*, Artículo 104096. https://doi.org/10.1016/j.jisa.2025.104096

Congreso de la República del Perú. (2011, 3 de julio). *Ley N.° 29733, Ley de Protección de Datos Personales*. https://www.leyes.congreso.gob.pe/DetLeyNume_1p.aspx?xNorma=6&xNumero=29733&xTipoNorma=0

Cybersecurity and Infrastructure Security Agency, National Security Agency, Federal Bureau of Investigation, Multi-State Information Sharing and Analysis Center, & Israel National Cyber Directorate. (2023, 6 de junio). *Guide to securing remote access software*. https://www.ic3.gov/CSA/2023/230606.pdf

Cybersecurity and Infrastructure Security Agency, National Security Agency, Federal Bureau of Investigation, & Multi-State Information Sharing and Analysis Center. (2023, octubre). *#StopRansomware guide*. https://www.ic3.gov/CSA/2023/231019.pdf

Dora, J. R., & Hluchý, L. (2026). Adversarial exploitation of Remote Desktop Protocol (RDP) for lateral movement. En *Proceedings of the 17th International Conference on Information and Communication Systems* (artículo 3, pp. 1–6). Association for Computing Machinery. https://doi.org/10.1145/3812734.3813403

Federal Bureau of Investigation, Cybersecurity and Infrastructure Security Agency, Europol's European Cybercrime Centre, & National Cyber Security Centre of the Netherlands. (2024, 18 de abril). *#StopRansomware: Akira ransomware (Aviso AA24-109A)*. https://www.cisa.gov/sites/default/files/2024-04/aa24-109a-stopransomware-akira-ransomware_2.pdf

Gandhi, V., Banerjee, S., Agrawal, A., Ahmad, A., Lee, S., & Peinado, M. (2023). Rethinking system audit architectures for high event coverage and synchronous log availability. En *Proceedings of the 32nd USENIX Security Symposium* (pp. 391–408). USENIX Association. https://www.usenix.org/conference/usenixsecurity23/presentation/gandhi

González-Granadillo, G., González-Zarzosa, S., & Diaz, R. (2021). Security information and event management (SIEM): Analysis, trends, and usage in critical infrastructures. *Sensors, 21*(14), Artículo 4759. https://doi.org/10.3390/s21144759

Guttman, B., White, D. R., Williams, S., & Walraven, T. (2022). *Digital evidence preservation: Considerations for evidence handlers (NIST IR 8387)*. National Institute of Standards and Technology. https://doi.org/10.6028/NIST.IR.8387

Hassan, W. U., Guo, S., Li, D., Chen, Z., Jee, K., Li, Z., & Bates, A. (2019). NoDoze: Combatting threat alert fatigue with automated provenance triage. En *Proceedings of the Network and Distributed System Security Symposium (NDSS 2019)*. Internet Society. https://doi.org/10.14722/ndss.2019.23349

Hastings, S., Bolger, C., Shumway, P., & Moore, T. (2024). Transforming raw authentication logs into interpretable events. En *Proceedings of the Workshop on SOC Operations and Construction (WOSOC 2024)*. Internet Society. https://doi.org/10.14722/wosoc.2024.23003

He, J., Song, C., Hu, R., & Ren, Z. (2026). LogHGAD: A hypergraph-based log anomaly detection method for AIoT systems. *Journal of Systems Architecture, 170*, Artículo 103630. https://doi.org/10.1016/j.sysarc.2025.103630

Hornyák, O. (2022). Távoli asztal kapcsolat feltörésének elemzése [Investigación de un ataque a una conexión de escritorio remoto]. En *XXIII. ENELKO – XXXII. SzámOkt* (pp. 113–118). Erdélyi Magyar Műszaki Tudományos Társaság. https://ojs.emt.ro/enelko-szamokt/hu/article/view/1022

International Organization for Standardization. (2022). *Information security, cybersecurity and privacy protection — Information security management systems — Requirements (ISO/IEC 27001:2022)*. https://www.iso.org/standard/27001?archive=all

Ispahany, J., Islam, M. R., Khan, M. A., & Islam, M. Z. (2025). *iCNN-LSTM: A batch-based incremental ransomware detection system using Sysmon* [Prepublicación]. arXiv. https://doi.org/10.48550/arXiv.2501.01083

Jiang, P., Huang, R., Li, D., Guo, Y., Chen, X., Luan, J., Ren, Y., & Hu, X. (2023). Auditing frameworks need resource isolation: A systematic study on the super producer threat to system auditing and its mitigation. En *Proceedings of the 32nd USENIX Security Symposium* (pp. 355–372). USENIX Association. https://www.usenix.org/conference/usenixsecurity23/presentation/jiang-peng

Jin, P., Kim, N., & Jeong, D. (2025). Enhancing DFIR in orchestration environments: Real-time forensic framework with eBPF for Windows. *Forensic Science International: Digital Investigation, 53*, Artículo 301923. https://doi.org/10.1016/j.fsidi.2025.301923

Joint Task Force Transformation Initiative. (2012, septiembre). *Guide for conducting risk assessments (NIST SP 800-30 Rev. 1)*. National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-30r1

Kist, A. A., & Maxwell, A. D. (2012). Network performance and quality of experience of remote access laboratories. *International Journal of Online Engineering (iJOE), 8*(4), 50–57. https://doi.org/10.3991/ijoe.v8i4.2276

Kuzminykh, I., Ghita, B., & Silonosov, A. (2020). *Impact of network and host characteristics on the keystroke pattern in remote desktop sessions* [Prepublicación]. arXiv. https://doi.org/10.48550/arXiv.2012.03577

Lai, A. M., & Nieh, J. (2006). On the performance of wide-area thin-client computing. *ACM Transactions on Computer Systems, 24*(2), 175–209. https://doi.org/10.1145/1132026.1132029

Landauer, M., Hotwagner, W., Boenke, T., Skopik, F., & Wurzenberger, M. (2026). CAM-LDS: Cyber attack manifestations for automatic interpretation of system logs and security alerts. *International Journal of Information Security, 25*(5), Artículo 148. https://doi.org/10.1007/s10207-026-01318-x

Lapczyk, L., & Skillicorn, D. B. (2020). *Activity detection from encrypted Remote Desktop Protocol traffic* [Prepublicación]. arXiv. https://doi.org/10.48550/arXiv.2008.02685

Lisnevskyi, R., Amanzholova, S., Akhmetzhanova, J., Ikembayeva, A., & Naumova, D. (2026). Development of an integrated network threat detection system based on Wazuh, Suricata and Telegram Bot. En K. Kolesnikova & M. Ipalakova (Eds.), *Proceedings of the Workshop on Cybersecurity, Infocommunication Systems and Networks 2025* (Vol. 4180). CEUR Workshop Proceedings. https://ceur-ws.org/Vol-4180/Paper3.pdf

Lyle, J. R., Guttman, B., Butler, J. M., Sauerwein, K., Reed, C., & Lloyd, C. E. (2022). *Digital investigation techniques: A NIST scientific foundation review (NIST IR 8354)*. National Institute of Standards and Technology. https://doi.org/10.6028/NIST.IR.8354

Magaña, E., Sesma, I., Morató, D., & Izal, M. (2019). Remote access protocols for Desktop-as-a-Service solutions. *PLOS ONE, 14*(1), Artículo e0207512. https://doi.org/10.1371/journal.pone.0207512

Mahendrawathi, E. R., van der Waal, W., Beerepoot, I., Putra, M. A. R. R., & Propitadewa, H. (2025). Understanding student behavior using active window tracking and process mining. En A. Delgado & T. Slaats (Eds.), *Process*

mining workshops: ICPM 2024 international workshops (pp. 117–128). Springer. https://doi.org/10.1007/978-3-031-82225-4_9

Manson, J. (2022). Remote desktop software as a forensic resource. *Journal of Cyber Security Technology, 6*(1–2), 1–26. https://doi.org/10.1080/23742917.2022.2049560

Marín Zúñiga, D. X. (2019). *Implementación de un prototipo de plataforma virtual que soporte el software y aplicaciones académicas utilizadas en la carrera de Ingeniería Electrónica* [Trabajo de titulación, Universidad del Azuay]. Repositorio Institucional de la Universidad del Azuay. https://dspace.uazuay.edu.ec/bitstream/datos/9373/1/15011.pdf

Martínez Urbina, A. G., De la O Aguilar, C. E., & Lemus Hernández, W. A. (2007). *Implementación de un centro de cómputo experimental, en la Escuela de Informática de la Universidad Tecnológica, reutilizando equipos considerados obsoletos y empleando tecnología de servidor de terminales gráficas, sobre plataforma Microsoft Windows* [Trabajo de graduación, Universidad Tecnológica de El Salvador]. Biblioteca UTEC. https://biblioteca.utec.edu.sv/siab/virtual/tesis/941000677.pdf

Meijerink, M. (2019). *Anomaly-based detection of lateral movement in a Microsoft Windows environment: Using the Windows security event log for detecting lateral movement techniques executed by a professional red team* [Tesis de maestría, University of Twente]. University of Twente Student Theses. https://essay.utwente.nl/77122/1/Meijerink_MA_EWI.pdf

Microsoft. (2018a, 31 de mayo). *Remote Desktop Protocol*. Microsoft Learn. https://learn.microsoft.com/en-us/windows/win32/termserv/remote-desktop-protocol

Microsoft. (2018b, 31 de mayo). *Remote Desktop sessions*. Microsoft Learn. https://learn.microsoft.com/en-us/windows/win32/termserv/terminal-services-sessions

Microsoft. (2021a, 6 de septiembre). *Audit logon*. Microsoft Learn. https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/auditing/audit-logon

Microsoft. (2021b, 5 de septiembre). *Audit other logon/logoff events*. Microsoft Learn. https://learn.microsoft.com/en-us/previous-versions/windows/it-pro/windows-10/security/threat-protection/auditing/audit-other-logonlogoff-events

Microsoft. (2024a, 30 de octubre). *Remote Desktop and web services (MS-AUTHSOD, sección 2.1.2.3.2)*. Microsoft Learn. https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-authsod/32f5a0b9-21d9-4b9c-b7d1-e80d72db47a7

Microsoft. (2024b, 4 de junio). *Windows Server 2022: Microsoft Lifecycle*. Microsoft Learn. Recuperado el 9 de noviembre de 2026, de https://learn.microsoft.com/en-us/lifecycle/products/windows-server-2022

Microsoft. (2026a, 12 de febrero). *Ports that are used by Remote Desktop Services*. Microsoft Learn. https://learn.microsoft.com/en-us/troubleshoot/windows-server/remote/ports-used-by-rds

Microsoft. (2026b, 9 de marzo). *Remote Desktop Protocol: Basic connectivity and graphics remoting (MS-RDPBCGR, revisión 62.0)*. Microsoft Learn. https://learn.microsoft.com/en-us/openspecs/windows_protocols/ms-rdpbcgr/5073f4ed-1e93-45e1-b039-6e30c385867c

Ministerio de Justicia y Derechos Humanos. (2024, 30 de noviembre). *Decreto Supremo N.° 016-2024-JUS que aprueba el Reglamento de la Ley N.° 29733, Ley de Protección de Datos Personales*. https://www.gob.pe/institucion/anpd/normas-legales/6554453-n-016-2024-jus

MITRE. (2026a, 4 de noviembre). *Brute force: Password spraying (T1110.003, versión 1.8)*. MITRE ATT&CK. https://attack.mitre.org/techniques/T1110/003/

MITRE. (2026b, 12 de mayo). *Remote services: Remote Desktop Protocol (T1021.001, versión 1.4)*. MITRE ATT&CK. https://attack.mitre.org/techniques/T1021/001/

Mosquera Asimbaya, J. A., & Viñamagua Quezada, D. J. (2015). *Sistema distribuido para gestión del laboratorio de informática de la FIEE* [Proyecto de titulación, Escuela Politécnica Nacional]. Repositorio Digital EPN. https://bibdigital.epn.edu.ec/bitstream/15000/11512/1/CD-6492.pdf

Multi-State Information Sharing and Analysis Center. (2019, enero). *Remote Desktop Protocol (Security Primer SP2019-0102)*. Center for Internet Security. https://www.cisecurity.org/-/media/project/cisecurity/cisecurity/data/media/files/uploads/2019/01/MS-ISAC-Security-Primer-RDP.pdf

Nashivochnikov, N., Vitkova, L., Lukashin, A., & Chechulin, A. (2025). Anomaly detection in Windows event logs for ransomware identification. En *2025 International Ural Conference on Electrical Power Engineering (UralCon)* (pp. 556–561). IEEE. https://doi.org/10.1109/URALCON67204.2025.11206632

National Institute of Standards and Technology. (2024, 26 de febrero). *The NIST cybersecurity framework (CSF) 2.0 (NIST CSWP 29)*. https://doi.org/10.6028/NIST.CSWP.29

Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K. (2025, abril). *Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile (NIST SP 800-61 Rev*. 3). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-61r3

Pessolani, P. A. (2011). Análisis de las características del tráfico de escritorios virtuales mediante el parámetro de Hurst. En *Actas del XII Argentine Symposium on Technology (AST 2011), 40 JAIIO* (pp. 21–32). Sociedad Argentina de Informática e Investigación Operativa. https://sedici.unlp.edu.ar/handle/10915/125323

Puchalt Rodríguez, A. E., & Gómez García, P. J. (2014). *Implementación de los servicios Terminal Server en un sistema corporativo* [Proyecto final de carrera, Universitat Politècnica de València]. RiuNet. https://riunet.upv.es/server/api/core/bitstreams/88f9af84-dd84-43cd-9dd2-6c7dcc89c472/content

Radah, T., Chaoui, H., & Saadi, C. (2023). Detecting unconventional and malicious Windows authentication activities through statistical rarity assessment. *International Journal of Safety and Security Engineering, 13*(5), 773–780. https://doi.org/10.18280/ijsse.130501

Rekhter, Y., Moskowitz, B., Karrenberg, D., de Groot, G. J., & Lear, E. (1996, febrero). *Address allocation for private internets (RFC 1918)*. RFC Editor. https://doi.org/10.17487/RFC1918

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). *Zero trust architecture (NIST Special Publication 800-207)*. National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207

Ruambo, F. A., Masanga, E. E., Lufyagila, B., Ateya, A. A., Abd El-Latif, A. A., Almousa, M., & Abd-El-Atty, B. (2025). Brute-force attack mitigation on remote access services via software-defined perimeter. *Scientific Reports, 15*, Artículo 18599. https://doi.org/10.1038/s41598-025-01080-5

Sanjalawe, Y., Al-E'mari, S., & Makhadmeh, S. N. (2026). Forensic-BERT: Explainable transformer-based detection of concealed evidence in cross-platform volatile memory. *Computers, 15*(7), Artículo 420. https://doi.org/10.3390/computers15070420

Schlosser, D., Binzenhöfer, A., & Staehle, B. (2007). Performance comparison of Windows-based thin-client architectures. En *2007 Australasian Telecommunication Networks and Applications Conference* (pp. 197–202). IEEE. https://doi.org/10.1109/ATNAC.2007.4665260

Şeşen, E., & Kara, R. (2018). Masaüstü sanallaştırma teknolojilerindeki bağlantı protokollerinin karşılaştırılması [Comparación de protocolos de conexión en tecnologías de virtualización de escritorios]. *Düzce Üniversitesi Bilim ve Teknoloji Dergisi, 6*(1), 216–222. https://doi.org/10.29130/dubited.350552

Siadati, H., & Memon, N. (2017). Detecting structurally anomalous logins within enterprise networks. En *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security* (pp. 1273–1284). Association for Computing Machinery. https://doi.org/10.1145/3133956.3134003

Smiliotopoulos, C., Barmpatsalou, K., & Kambourakis, G. (2022). Revisiting the detection of lateral movement through Sysmon. *Applied Sciences, 12*(15), Artículo 7746. https://doi.org/10.3390/app12157746

Smiliotopoulos, C., Kambourakis, G., & Barbatsalou, K. (2023). On the detection of lateral movement through supervised machine learning and an open-source tool to create turnkey datasets from Sysmon logs. *International Journal of Information Security, 22*(6), 1893–1919. https://doi.org/10.1007/s10207-023-00725-8

Souppaya, M., & Scarfone, K. (2016). *Guide to enterprise telework, remote access, and bring your own device (BYOD) security (NIST Special Publication 800-46, revisión 2)*. National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-46r2

Tanimu, J. A., Bendiab, G., Kanta, A., & Shiaeles, S. (2026). AI-driven threat detection and automated incident response for enhancing network security. *Network, 6*(2), Artículo 32. https://doi.org/10.3390/network6020032

Tuyishime, E., Balan, T. C., Cotfas, P. A., Cotfas, D. T., & Rekeraho, A. (2023). Enhancing cloud security—Proactive threat monitoring and detection using a SIEM-based approach. *Applied Sciences, 13*(22), Artículo 12359. https://doi.org/10.3390/app132212359

Uetz, R., Herzog, M., Hackländer, L., Schwarz, S., & Henze, M. (2024). You cannot escape me: Detecting evasions of SIEM rules in enterprise networks. En *Proceedings of the 33rd USENIX Security Symposium* (pp. 5179–5196). USENIX Association. https://www.usenix.org/conference/usenixsecurity24/presentation/uetz

Vaarandi, R., & Mäses, S. (2022). How to build a SOC on a budget. En *2022 IEEE International Conference on Cyber Security and Resilience (CSR)* (pp. 171–177). IEEE. https://doi.org/10.1109/CSR54599.2022.9850281

Vitla, S. (2024). Unsecured Remote Desktop Protocol (RDP) access: A gateway for ransomware attacks and corporate extortion. *Journal of Computer Science and Technology Studies, 6*(2), 150–165. https://doi.org/10.32996/jcsts.2024.6.2.17

Vizváry, M., & Vykopal, J. (2013). Flow-based detection of RDP brute-force attacks. En *Security and Protection of Information 2013* (pp. 131–138). University of Defence. https://repozitar.cz/repo/16350/

Wireshark Foundation. (s. f.). *tshark(1)*. Wireshark User's Guide. https://www.wireshark.org/docs/man-pages/tshark

Yan, T., & Chen, J. (2019, 29 de agosto). *Exploitation of Windows CVE-2019-0708 (BlueKeep): Three ways to write data into kernel with RDP PDU*. Unit 42, Palo Alto Networks. https://unit42.paloaltonetworks.com/exploitation-of-windows-cve-2019-0708-bluekeep-three-ways-to-write-data-into-the-kernel-with-rdp-pdu/

Yang, J., Shen, H., Diao, Z., & He, Y. (2026). Enhancing fine-grained encrypted traffic classification via temporal bi-directional GraphSAGE. *Applied Sciences, 16*(7), Artículo 3427. https://doi.org/10.3390/app16073427

Yang, S. J., Nieh, J., Selsky, M., & Tiwari, N. (2002). The performance of remote display mechanisms for thin-client computing. En *Proceedings of the 2002 USENIX Annual Technical Conference, General Track* (pp. 131–146). USENIX Association. https://www.usenix.org/event/usenix02/full_papers/yang/yang.pdf

Yu, L., Ye, Y., Zhang, Z., & Zhang, X. (2024). Cost-effective attack forensics by recording and correlating file system changes. En *Proceedings of the 33rd USENIX Security Symposium* (pp. 1705–1722). USENIX Association. https://www.usenix.org/conference/usenixsecurity24/presentation/yu-le

Zeas Martínez, R. C. (2011). *Análisis y captura de paquetes de datos en una red mediante la herramienta Wireshark* [Trabajo de titulación, Universidad Tecnológica Israel]. Repositorio Digital Universidad Israel. https://repositorio.uisrael.edu.ec/handle/47000/168

ANEXOS

Los anexos A–I, P y Q se incorporan al informe. Los anexos J–O se entregan como archivos editables en 06_Evidencias_y_enlaces/Anexos_tecnicos. El Anexo Q reúne la evidencia documental que sustenta el problema de adquisición y asociación de registros.

ANEXO A. DIAGRAMAS A TAMAÑO COMPLETO

Las Figuras 1 a 7 del cuerpo también están disponibles a resolución completa en la carpeta 03_Diagramas. El número inicial del archivo identifica la figura del informe.

ANEXO B. TABLA COMPLETA DE EVENTOS DE WINDOWS

Archivo editable: Anexo_B_Eventos_de_Windows.csv. Disponible en 06_Evidencias_y_enlaces/Anexos_tecnicos.

La Tabla B1 identifica los eventos de Windows seleccionados.

Tabla B1

Eventos de Windows seleccionados

Evento	Proveedor o canal	Campos a conservar	Aplicación y condición
4624	Security	TargetLogonId, LogonType, IpAddress, IpPort, SID o alias	Tipo 10 confirma inicio remoto interactivo.
4625	Security	TargetUserName, LogonType, IpAddress, Status, SubStatus	Fallo. Tipo 3 requiere contexto de RDP.
4634	Security	TargetLogonId, LogonType	Cierre completado.
4647	Security	SubjectLogonId	Cierre solicitado por el usuario.
4672	Security	SubjectLogonId, PrivilegeList reducida	Privilegios especiales asociados al inicio.
4688	Security	NewProcessName, NewProcessId, SubjectLogonId, TargetLogonId si existe	Creación de ejecutable permitido. Excluir CommandLine.
1102	Security	SubjectUserSid, SubjectLogonId	Señal operativa de borrado del registro.
1149	RemoteConnectionManager/Operational	Cuenta, dominio y dirección si disponibles	Autenticación de red RDP. Requiere contexto para confirmar sesión.
21 / 22	LocalSessionManager/Operational	SessionID, User, Address cuando exista	Inicio de sesión y shell.
23 / 24 / 25	LocalSessionManager/Operational	SessionID, User, Address cuando exista	Cierre, desconexión y reconexión.
6005 / 6006	System / EventLog	EventRecordID, TimeCreated	Inicio o detención del servicio de eventos.
6008	System / EventLog	TimeCreated y datos del proveedor	Evidencia de apagado inesperado.
4778	Security	AccountName, AccountDomain, LogonID, SessionName, ClientName, ClientAddress	Reconexión. Corrobora LSM 25. No incrementa el puntaje por sí sola.
4779	Security	AccountName, AccountDomain, LogonID, SessionName, ClientName, ClientAddress	Desconexión. Corrobora LSM 24. Conservar ambas procedencias para una sola transición.

Nota. Elaboración propia.

ANEXO C. DICCIONARIO DE DATOS

Archivo editable: Anexo_C_Diccionario_de_datos.csv. Disponible en 06_Evidencias_y_enlaces/Anexos_tecnicos.

La Tabla C1 presenta el diccionario de datos.

Tabla C1

Diccionario de datos

Entidad	Clave / campos	Validación y uso
host	host_id, alias, certificado, zona	Certificado asociado a un host habilitado.
evidence	evidence_id, host_id, source_key, kind, timestamps, payload	Clave de fuente única. Fechas UTC, campos permitidos.
flow	flow_id, host_id, extremos, protocolo, inicio, último paquete, bytes	Puertos válidos, bytes no negativos, dirección registrada.
attempt	attempt_id, host_id, cuenta, origen, resultado, calidad	Resultado éxito, fallo o indeterminado.
session	session_uuid, host_id, boot_id, session_id, logon_key, estado	Identificadores locales no globales. Control de estados.

Entidad	Clave / campos	Validación y uso
evidence_link	link_id, evidence_id, attempt_id o session_uuid, método, versión, delta	Cada vínculo tiene un destino y procedencia.
alert	alert_id, caso, score, severidad, ruleset, estado	Puntaje 0–100. Versión persistida.
alert_rule	alert_id, rule_id, puntos, evidencia_id	Permite reconstruir por qué se asignó el puntaje.
audit_log	audit_id, actor, acción, fecha, resultado	Registrar acceso, exportación, cambios y denegaciones.

Nota. Elaboración propia.

ANEXO D. REGLAS DE DETECCIÓN DETALLADAS

Archivo editable: Anexo_D_Reglas_de_deteccion.csv. Disponible en 06_Evidencias_y_enlaces/Anexos_tecnicos.

ANEXO E. MATRIZ DE TRAZABILIDAD

Archivo editable: Anexo_E_Matriz_de_trazabilidad.csv. Disponible en 06_Evidencias_y_enlaces/Anexos_tecnicos.

ANEXO F. PROTOTIPO EN FIGMA (CAPTURAS Y ENLACE)

Abrir el archivo editable de Figma

Abrir el recorrido del analista

Véase la Figura 9.

Figura 9

Detalle de una alerta en Figma



Nota. Captura del prototipo propio en Figma con datos simulados.

La carpeta 04_Prototipo reúne cinco capturas del resumen, el detalle de alerta y el recorrido por los casos de diseño. La evidencia de navegación se complementa con el enlace editable. La prueba CP-08 con cinco participantes queda planificada.

ANEXO G. REGISTRO DE CONTROL DE FUENTES ACTUALIZADO

El corpus conserva 83 PDF. La bibliografía final reúne 88 referencias citadas. La Tabla 27 lo desglosa.

Tabla 27

Inventario bibliográfico por tema

Tema	PDF revisables	Copias identificadas como duplicadas
Fundamentos RDP	14	0
Tráfico RDP	13	1
Registros y correlación	14	0
Seguridad y amenazas	14	0
Herramientas y monitoreo	14	1
Detección y análisis forense	14	0

Nota. Elaboración propia.

La matriz distingue la existencia de la fuente y el nivel de cotejo de sus metadatos. La coincidencia del DOI o el acceso a la URL documenta la identificación. La comprobación de autoría, fecha y pertinencia requiere contrastar cada registro.

La bibliografía, el registro de verificación y las referencias citadas se entregan en 05_Fuentes.

El Anexo G registra las 88 entradas y consigna la evidencia consultada para cada cotejo. Se corrigieron la lista de autores del informe NIST IR 8387, el año del artículo LogHGAD, la inicial de Azahari en la ficha editorial, el título de las actas de Chapple et al. y el número de artículo de Dora y Hluchý.

ANEXO H. GLOSARIO

Glosario editable: Anexo_H_Glosario_operativo.csv. Disponible en 06_Evidencias_y_enlaces/Anexos_tecnicos.

ANEXO I. ENLACE AL REPOSITORIO

Repositorio del equipo en GitHub · Versión anterior publicada en Google Drive

Anexos J a O en 06_Evidencias_y_enlaces/Anexos_tecnicos. Casos y capturas en 04_Prototipo.

ANEXO P. COMPARACIÓN CON SISTEMAS AFINES

La Tabla 28 contrasta este diseño con los cuatro sistemas de la literatura que persiguen un objetivo equivalente. Las columnas recogen solo los criterios que deciden la elección; las métricas de cada trabajo pertenecen a su propio entorno y no se trasladan al laboratorio.

Tabla 28

Comparación con los sistemas afines

Criterio	NoDoze (2019)	Wazuh + Suricata (2026)	NDR abierto (2025)	SIEM de bajo costo (2022)	Este diseño
Enfoque	Triaje de alertas por procedencia	Correlación con HIDS y reglas	Sensores de red	SOC con presupuesto limitado	Correlación host y red
Evidencia	Trazas del host	Registros del host y alertas	Tráfico de red	Fuentes múltiples	Security y Terminal Services con flujos 3389
Modelo entrenado	Sí	No	No	No	No: reglas versionadas
Asociación intento–flujo	No la aborda	Parcial, por regla	Solo lado de red	No	Explícita; conserva la ambigüedad
Puntaje versionado	No	No	No	No	Sí: R-01 a R-07 (Anexo O)
Costo de operación	Alto	Medio	Medio	Bajo	Bajo: cuatro VM

Nota. Elaboración propia a partir de Hassan et al. (2019), Lisnevskyi et al. (2026), Amoretti (2025) y Vaarandi y Mäses (2022).

Nota de formato. El informe conserva la plantilla de la Escuela, con Arial 10,5 pt y espaciado sencillo en el cuerpo. La lista de referencias usa doble espacio y sangría francesa.

ANEXO Q. EVIDENCIA DOCUMENTAL DEL LABORATORIO

Q.1. Antecedente de adquisición y correlación

La Tabla Q1 presenta el contraste entre la captura y la exportación de eventos.

Tabla Q1

Ficha de evidencia del problema de correlación

Campo	Registro
Fecha e identificación	10/11/2026. Corrida identificada por 01_rdp.pcapng y el manifiesto.
Entorno	CLI-RDP y WIN-RDP en un conmutador privado. El host capturó TCP 3389.
Software observado	TShark 4.6.9 en las capturas. PCAP generado en Windows Server 2022 (21H2, compilación 20348).
Intervalo de paquetes	17:34:39,638 a 17:39:07,310 UTC. Extensión observada: 267,672 s.
Red	412 paquetes y 5 SYN iniciales de 10.20.99.10 a 10.20.99.20. Sin filas UDP en la exportación.
Eventos	4779, registro 1198, 17:39:07,173 UTC. 4624 tipo 5, registro 1204, 17:39:48,780 UTC.
Vínculo pendiente	El SYN del flujo 4 precede al 4779 por 8,603 s. El último paquete de ese flujo aparece 0,137 s después. El evento identifica el cliente, pero omite el puerto de origen.
Integridad	Coinciden los 4 hashes SHA-256 del manifiesto.
Dictamen	La captura registra inicios de flujo y el 4779 acredita una desconexión. El vínculo con TCP 4 queda sin confirmar y el 4624 tipo 5 documenta el inicio de un servicio.

Nota. Elaboración propia.

Trazabilidad. Los archivos originales se conservan en 08_evidencia_preliminar. El CSV Anexo_Q_Contraste_de_evidencia.csv presenta los flujos, los registros y las marcas UTC verificadas. El contraste usa las marcas de tiempo del CSV de Windows y del PCAP.